

Zobba: Consolidated Product and Architecture Design

Zobba: the audit working environment

The recommendation

1. Product model
2. Interaction, control and collaboration
3. Permissions, methodology and knowledge
4. Work products, evidence and continuing assurance
5. Target architecture
6. Engine, models and tools
7. Computers, analysis and credential custody
8. Normal work, recovery and operational guarantees
9. What to keep, adapt, rebuild and remove
10. Replace the planning model coherently
11. Capability dependencies
12. Remaining business decisions
13. Evidence, scope and review status

Zobba: the audit working environment

Consolidated product and architecture · 30 September 2026 · Revision 2 · For owner review

This is the lead Zobba design, consolidated against the alternate agent's document at the user's request. The clean Rust backend, fresh schema, continuing Task, real managed computer and standing Permissions remain the direction. The alternate document is a completeness source; its infrastructure choices, approval ceremonies and delivery stages do not govern this design. This is product and architecture design, not an implementation plan or a claim that these capabilities are already built.

The recommendation

Build Zobba around a continuing **Task inside an Engagement**. The auditor sets an objective through conversation. Zobba gathers material, uses a real computer when needed, runs analysis, investigates relevant leads and develops work products. The auditor can inspect the basis, guide the work, take control and review the result. That working relationship continues across tab closures, questions, new evidence and recurring checks.

Keep the Pair identity and the useful parts of the current conversation/workspace design. Build one Rust application backend and agent engine, with a fresh PostgreSQL schema. Retire compiler-1 and the procedure-first Builder. Preserve the current evidence, review and recovery behaviours that remain valuable, translating their tests into the new model rather than preserving their old tables and services.

The recommended system uses:

- A React and TypeScript web application, with conversation beside documents, data or the actual computer.
- A Rust modular backend: Axum, Tokio, SQLx, native model adapters and one authority for task commands and state.
- PostgreSQL for application state, accepted commands, durable work, leases and receipts; S3 for immutable evidence and versioned files.
- Managed Linux computers on isolated EC2 instances, with real browser/desktop viewing through an input gateway and Guacamole. A separate Windows/Office profile serves engagements that require those applications.
- Isolated, disposable analysis environments. They receive selected evidence and programs, without the credentials or browser sessions used to acquire it.
- Firm-defined methodology and review, plus Permissions bound to the actual account, system, purpose and action.

The main cost is building a dependable working environment and its operating controls. Rust provides a coherent ownership model and useful correctness tools; it is not a promise of faster remote models or cheaper computers.

The remaining business decisions are in §12. The architecture and ordinary engineering choices are resolved below. The capability dependencies in §11 put methodology, skills and working knowledge inside the first complete task experience; they are not an epic backlog.

1. Product model

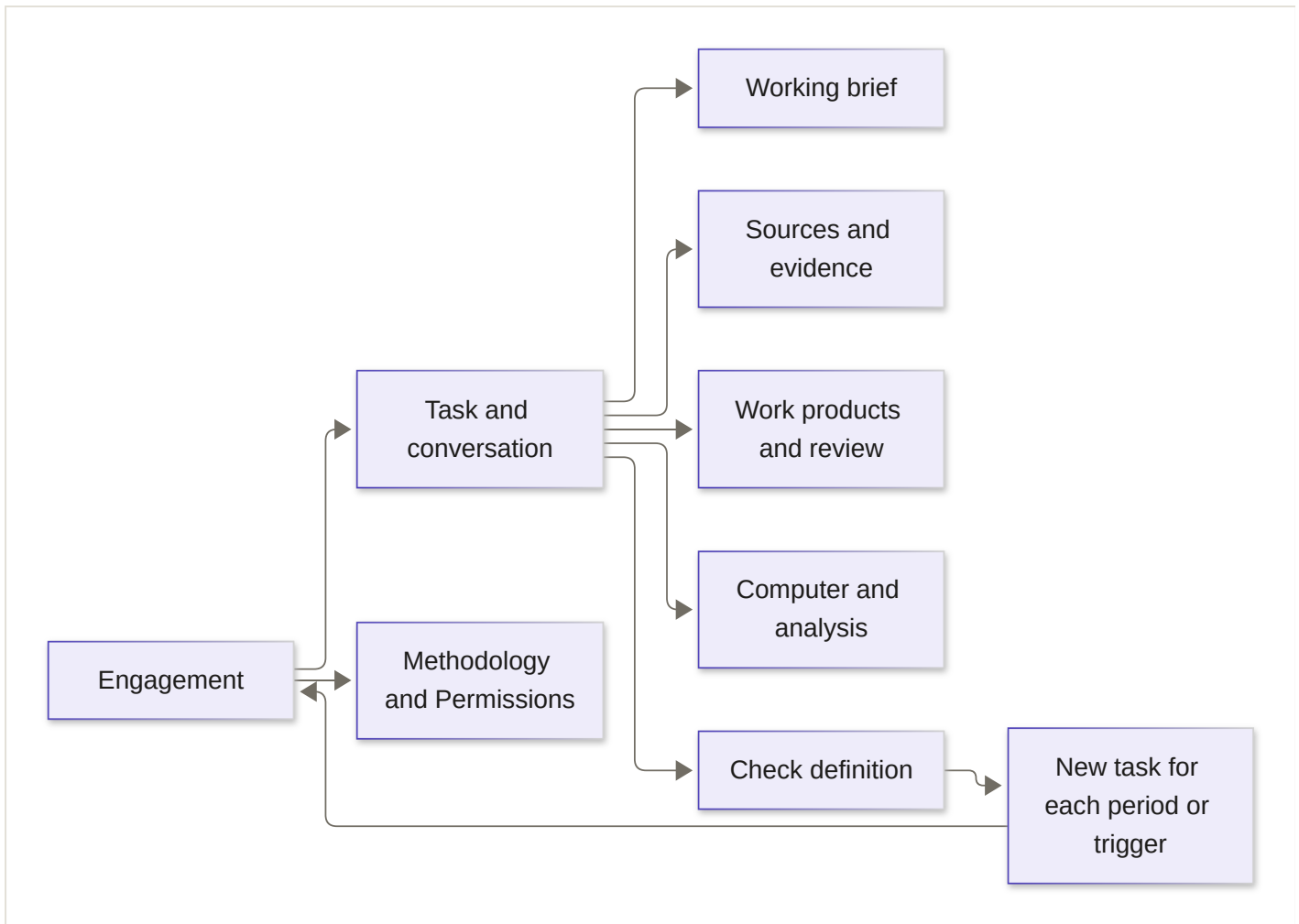
1.1 What the auditor is working with

An **Engagement** is the durable business context: client, period, objectives, team, methodology, material, Permissions and audit record. A **Task** is a continuing objective within that engagement. A Task can produce several work products and can remain useful long after its first answer.

The visible nouns are deliberately few:

Product object	Meaning to the auditor
Engagement	The audit context and the people responsible for it.
Task	An objective, its conversation, work, decisions and outstanding questions.
Working brief	Zobba’s current understanding of the objective, scope, approach and expected outputs. It evolves visibly.
Sources	Connected locations and acquired material, including what is missing or has changed.
Work products	Working papers, analyses, findings, reports, correspondence and other useful outputs.
Permissions	What Zobba may do, where, under whose authority and when it must ask.
Check	A reviewed, repeatable method with a schedule or trigger. Each execution creates its own linked Task and result.

The computer is a resource used by a Task. It is not the Task’s memory, identity or evidence store. A browser closing must not erase a question, a decision or a working paper.



Design diagram 1

A Task belongs to one engagement. Cross-client search may locate authorised items and show their client labels, but it must not silently combine their content into one task. Cross-engagement work within a client is an explicit scope change with source references and authorisation.

1.2 The working surface

Use the accepted Pair layout as the foundation:

- **Navigation:** New task, Search, Engagements, Scheduled checks and Recent tasks. Audit managers have Reviews. Connections and Settings remain secondary.
- **Conversation:** the objective, useful explanations, questions, accepted guidance and links to work. The composer stays usable during execution.
- **Workspace:** Computer, Data, Documents, Evidence and Changes, opened according to the work. A small activity view answers what happened and what needs attention.
- **Task header:** engagement, readable task state, accountable owner, Permissions and model configuration.

Conversation is always recoverable. The workspace remembers what the person is inspecting. Keep Pin, Expand, Close and the "From [task]" attribution. Selecting, pinning or editing an object suspends following; new content appears as an "Open" card in conversation. **Follow Zobba** explicitly resumes following. Elapsed time alone never decides that the person has finished inspecting something.

The computer panel shows the actual browser or desktop, its account and environment, who controls it, and whether the view is current. It must never substitute a plausible reconstruction for a disconnected session. Data and document views are first-class working surfaces, not screenshots of a desktop application when a native table or document is more useful.

How it ran opens the applicable methodology and skill versions, working knowledge used, sources and analyses, requested/actual model and effort, Permissions basis, human intervention intervals and observed outcomes. It explains the basis of the work without exposing private model reasoning or forcing an auditor to read an execution log.

On a narrow screen, use Conversation and Workspace tabs with persistent task state and a reachable Pause/Stop control. Keep decisions and evidence inspection fully usable. Computer control opens a full-screen view with explicit keyboard, pointer and zoom controls; warn when the target application needs a larger display. Do not imply that a dense desktop spreadsheet is comfortably editable on a phone.

Keep Graphite, Linen, Canvas and Iris, the Pair mark, accessible input/focus tokens, and the restrained typographic changes view. Zobba's chrome surrounds firm-owned deliverables. The firm's reference scheme, typography, logos and required sections govern the exported work product.

1.3 A complete task journey

Start with work. From an engagement, the auditor says: "Review leaver access for this quarter. Use SharePoint and the access system. Investigate unusual cases and prepare our working paper." Zobba uses the known engagement, methodology and connections. It begins useful discovery and shows a compact Working brief. It asks only when the answer changes scope, criteria, access or a consequential decision. An ambiguous engagement must be resolved before client material is disclosed or acquired.

On first use, New task can establish the client and engagement conversationally. The task binds the applicable saved methodology, allowed skills and relevant authorised working knowledge before substantive evaluation. A clearly labelled neutral working-paper template is available when the firm has none. Authorised discovery and drafting can begin while methodology configuration is incomplete; Zobba names the missing criteria or review rules and withholds only the conclusion or issuance that depends on them. It never presents a generic starter template as the firm's adopted methodology.

Establish the basis. Zobba identifies the applicable policy and period, gathers the population, checks coverage and exposes conflicts. If two policies disagree, it presents the difference and asks which governs. It can continue an independent inventory while that decision is pending. Missing access is a sign-in or connection request, not a request to paste credentials.

Do the work. Zobba selects the least fragile suitable route: direct API for acquisition, a browser or desktop for an application-only workflow, and a program for joining large datasets. It may investigate an unexpected pattern within the task objective, Permissions and budget. Material expansion of scope is proposed in the Working brief. It does not require the auditor to author every execution step.

Explain and inspect. "Why is this an exception?" opens the relevant criterion, source records, calculation and limitation beside the conversation. A selected sentence or cell is included as context when the auditor asks a question. The answer distinguishes recorded facts, analytical results and judgement. It can explain the basis without revealing private model reasoning.

Correct and collaborate. "Use the contractual termination date, not the payroll close date" is accepted durably at once. Zobba names the affected analysis and work products, applies the correction and creates a new version. An explicit edit to a draft does not need a second approval ceremony. A proposed

material change to an already presented conclusion is shown clearly; changes to reviewed work reopen the affected review.

Review and issue. Zobba prepares the firm template, maps claims to evidence and checks completeness against the methodology. The responsible human submits a version for review. The reviewer can challenge a claim, ask for work, accept a change or approve the exact version. Issuance is a separate authorised human action with its recipients and export package.

Continue. The auditor can return to the same task when evidence arrives, turn a successful method into a Check, or create a follow-up task linked to a finding. New work does not overwrite an approved or issued record.

1.4 Coverage across the audit cycle

Workflow	Zobba's work	Human responsibility and durable result
Engagement understanding and planning	Read prior work, policies and business information; identify gaps; draft scope, risks and an audit approach.	Auditor selects the objective and resolves material scope/criteria choices. Versioned planning work and decisions remain linked.
Evidence requests and walkthroughs	Draft or send authorised requests, organise responses, prepare questions, use permitted calendar tools and record supplied notes.	People approve external commitments when outside standing Permissions. Consent requirements for any recording follow firm policy.
Controls-design assessment	Relate control objectives, documented design, walkthrough evidence and identified gaps.	Auditor judges adequacy; Zobba does not turn a plausible narrative into a verified control.
Operating-effectiveness testing	Establish populations, select and record the method/sample, inspect records and explain exceptions.	Methodology governs selection, criteria, review and any inference to a population.
Investigation	Follow related transactions or events, compare sources and develop supported hypotheses.	Scope and budget stay visible; a hypothesis is not promoted to a finding without support.
Working papers and reporting	Produce calculations, papers, findings, draft reports and export packages with inspectable support.	Humans own preparation, review and issuance. Model-assisted checking is not an independent audit sign-off.

Workflow	Zobba's work	Human responsibility and durable result
Follow-up and ongoing checks	Revisit open findings, wait for evidence, run a reviewed recurring method and compare results.	Changed criteria or material source/method changes require a revised Check definition and appropriate review.

2. Interaction, control and collaboration

2.1 Task state should say what matters

The primary status is one readable phrase. Details disclose the underlying facts when useful:

User-visible state	Meaning and available action
Working	Useful activity is underway. Guide, inspect, pause, stop or take over an available computer.
Needs your input	A named question blocks specified work; independent work may continue. Answer or reassign it.
Needs sign-in	A particular account/application needs the named person's authentication. Open protected sign-in.
Needs permission	A concrete action exceeds standing authority. Review that action, edit it or refuse it.
Waiting for evidence / Scheduled	The task has a durable waiting condition, not a worker spinning in memory.
Pausing / Stopping	Control was accepted, but termination or effect reconciliation is not yet confirmed.
Paused	New work is withheld. Resume remains an explicit action.
Stopped	The requested activity has ended. Work is retained; unresolved external effects remain visibly unresolved.
Recovering	A machine or worker failed; Zobba is reconciling state. Do not show invented progress.
Ready for review / Complete	The work stage is complete. These labels do not imply a clean audit conclusion or human approval.

A Task can be active while one branch waits. It can finish with limitations. It can be stopped while an email's outcome is still unknown. These facts should not be forced into a single status enum.

2.2 Watch, guide, pause, stop and take over

Control	Product contract
Watch	View the current computer or work product without acquiring input control. Multiple authorised people may watch.
Guide	Persist a message immediately and acknowledge “Received”. Show “Applied” when it has actually changed the work. Offer “Interrupt now” for urgent corrections; do not imply guidance was applied merely because it was queued.
Pause	Stop admitting new work, cancel interruptible activity, preserve safe checkpoints and wait. Confirm Paused only after the relevant executors acknowledge quiescence or their unresolved state is disclosed.
Stop	End the current requested execution, prevent further work and reconcile dispatched effects. Preserve conversation, evidence and outputs. Resuming the objective starts a new recorded work cycle.
Take over	Acquire exclusive input control of a specified computer. Fence agent input at the actual gateway before enabling human input. Other independent analysis can continue only if it does not depend on that computer or conflict with the takeover.
Hand back	Release human input, discard stale screen assumptions, inspect the current application state and resume after revalidating account, purpose and pending operations.

Pause and Stop operate through a control path independent of the model stream. A slow provider call cannot prevent control acceptance. A disconnected browser is not a Stop command. If the control gateway cannot acknowledge a request, say so and fail closed at its lease boundary.

2.3 Sign-in and computer control

Computer control has its own states: **Agent controlling, Human controlling, Protected sign-in, Transferring control, Reconnecting, Stopped**. The UI names the human controller. A second person requests control rather than competing for the pointer.

Protected sign-in opens the real session. Passwords, MFA responses and recovery codes go into the application through a dedicated human input channel, never into conversation. During this interval, suspend agent observation, computer tool access, recording and extraction for that computer. Do not retain thumbnails or clipboard contents from the sign-in interval. The application and its operating system necessarily hold their own session material; the promise is containment from the model, task transcript and general analysis environment.

The person completes MFA and confirms that sign-in is done. Zobba then uses a fresh observation and a known account/application check. A cookie alone does not prove a successful or correct account login. If the identity or environment is uncertain, keep the computer unavailable for automated work.

Only the account owner or an explicitly permitted delegate can see and control protected sign-in. Other viewers receive a privacy cover. Purge queued frames and suspend task voice capture, DOM/accessibility extraction, OCR and all observation paths for that computer. Losing the human control connection fences input and leaves that computer paused; it never silently hands control to the agent.

For normal takeover, record the controller and interval. Respect the same application account and Permissions. Human control is not a route around live-source restrictions. "Hand back" describes what changed when the person knows it; Zobba still observes rather than trusting the description as proof of application state.

2.4 Several people and several helpers

The three roles remain **Auditor, Audit manager and Admin**. Auditors prepare work. Review, approval and issuance require an Audit manager role and the relevant engagement assignment. A person may hold more than one role; an independent practitioner can hold the audit roles needed for their declared solo methodology. Admin may configure methodology, users, connections, models and budgets; Admin alone confers no right to review or issue audit work.

Admin manages invitations, engagement assignments, role changes and account removal, with protection against removing the last active Admin. Removal terminates sessions and revokes current control/dispatch authority while preserving historical authorship. An Admin without the relevant engagement assignment cannot inspect client evidence merely by administering the platform.

Team engagements default to an Audit manager reviewing work prepared by another person. For independent practitioners, support an explicit solo mode that permits accountable self-review under the engagement's methodology; label it as self-reviewed and never as independent review. The same person may hold Auditor and Audit manager roles. Admin alone grants no audit sign-off. Admin configures the mode and its rules through ordinary saved configuration; a conversational instruction cannot override the task's binding or rewrite prior approvals. The review controls and exported labels in §4.2 make both modes explicit.

Several auditors can converse on a task and leave anchored review comments. Concurrent instructions are accepted in order; contradictory material direction becomes a named decision rather than "last message wins". Work product edits use version checks, visible changes and conflict resolution.

Helpers receive bounded subtasks with their own context, budget and scoped authority. They may analyse separate populations or prepare independent sections. They return results and evidence references to the parent. The parent owns synthesis and the final task explanation. Helpers do not share an unconstrained browser or write concurrently into the same document.

2.5 Speech

Speech is another input method to the same command system. Show the transcript and attach it to the task. The user may submit spoken guidance naturally; a transcription that could change a recipient, amount, system, test record or issued conclusion is shown for correction before that consequential action is authorised. Spoken “stop” uses the control path. Audio retention and permitted transcription destinations follow organisation policy; retaining raw audio is optional.

3. Permissions, methodology and knowledge

3.1 Three operating purposes

Permissions bind a real account and resource to an operating purpose, not merely to an application name:

Purpose	Routine allowed work	Boundary
Live inspection	Read selected operational records, export authorised populations and capture evidence.	No changes to live audited business records. Use target-side read-only identities wherever possible.
Test workflows	Create synthetic borrowers, submit test approvals and exercise a defined workflow in an explicitly designated test environment.	Bind environment identity, account, data scope, action classes, limits and cleanup. A hostname label saying “test” is insufficient.
Audit coordination	Work on audit copies, manage permitted task items and carry out defined document, email and calendar operations.	Sending, sharing or making commitments requires the applicable standing authority or a concrete decision. It does not grant operational-system write access.

These purposes can coexist in one engagement, but every operation has exactly one applicable purpose and capability. A test account never authorises production actions. A coordination connection does not let an agent update an audited ledger.

Routine internal coordination can use standing rules: known engagement recipients, allowed request templates, approved folders, attachment classifications and frequency limits. Default to drafts for new external recipients, broad sharing, financial/legal commitments and issued reports. Ask once for a well-defined standing rule when useful; do not ask before every routine calculation or permitted read.

The Permissions panel retains **Can read, Can write, Asks first, Never, Scheduled checks, Connections, Administrator limits** and **Activity record**. Show examples specific to the engagement. Avoid universal claims such as “this browser cannot change anything” when the underlying account can write.

Arbitrary browser/desktop actions cannot be made semantically read-only by a domain allowlist or a model prompt. For live inspection, require a source-enforced read-only account or a narrowly validated interaction adapter. Full human takeover is available only if that restriction survives the transfer; an adapter-only restriction cannot safely become unrestricted desktop input with a writable account. When neither route is available, use supplied exports or separately attributed manual evidence acquisition outside Zobba’s control. Do not represent that manual activity as technically enforced read-only automation.

3.2 How authority is determined

Effective authority is the intersection of current organisation limits, engagement scope, current membership, connection/account restrictions, the accepted Task's authority and any bounded delegation. Revocation narrows it immediately at the next enforcement boundary. A broader administrator policy does not silently enlarge an existing task; an explicit task authority change is required.

A confirmation binds the actual operation: account, destination, recipients, content and attachments, resource version, purpose and expiry. A material change requires a new decision. "Yes" in a conversation is useful only when it can be resolved to the current decision and reviewed content.

Methodology has typed standing:

- **Required controls:** review requirements, prohibited uses, retention obligations and required audit procedures. Enforced by application code and attributable, immutable configuration versions.
- **Engagement decisions:** scoped choices of criterion, period, treatment or method, with accountable author and rationale.
- **Skills:** optional techniques, templates and tool instructions, unless a named methodology requirement explicitly makes part of them mandatory.
- **Preferences:** presentation and working style, adjustable by the auditor.
- **Retrieved content:** evidence or reference material. Instructions embedded in it carry no authority to change Permissions, destinations or required review.

There is no single textual hierarchy that makes every skill instruction outrank the auditor. Conversely, an auditor's preference for a shorter paper cannot remove a required review or conceal a limitation.

3.3 Methodology becomes usable configuration

Admin edits, validates and saves methodology in Settings → Methodology and skills. There is no default second approver or separate publication ceremony. An Audit manager may advise on substance; the product does not require that person to approve Admin's ordinary edits. Admin can also ask Zobba to interpret uploaded methodology. The result is an editable proposal with source passages, conflicts and uncertain interpretations; only the Admin's Save makes it configuration.

A package contains applicable audit areas and periods, required/optional work, criteria and source authority, population/sampling conventions, evidence checks, rating vocabularies, templates and section mappings, review/issuance rules, and suitable skills. The Northstar/P-1-P-4 material is an opt-in example pack. A new firm uses its own pack or an explicitly labelled neutral starting package; demonstration criteria never become universal rules.

Save validates schema, references and effective assignments, then atomically creates an immutable version, records author/time/diff/sources, updates the selected assignment and adds change notifications. Invalid settings leave the previous version effective. Undo saves a successor. No one edits a version already cited by audit work. Admin owns these settings within fixed product truths: decisions remain attributable; issued history is preserved; self-review cannot be called independent; configuration authority does not confer audit sign-off.

The Save surface states its scope: **"New tasks in all engagements · effective now"** by default. Admin can select clients/engagements, a future effective date, or **"Also apply to active tasks"** within the same

edit. Firm defaults and explicit scoped overrides resolve field by field; an incomplete override cannot erase inherited requirements. Configuration availability and a criterion's business effective period are separate: a policy entered today may govern an earlier period, and "latest saved" is not a policy-selection rule.

Change	Effect on work
New task	Bind the applicable method/template versions and audit period before substantive evaluation. Show their identity in the Working brief.
Save for new tasks	Existing work keeps its recorded binding. Show an update notice where it changes that work, rather than a prompt for every typo.
Apply to active tasks	Commit a binding-change command; at a safe boundary, compare requirements, rebuild context and recompute affected draft dependencies. Report the change. Ask only about a new material ambiguity, authority gap or budget need.
Operation in flight	Preserve its original basis and actual outcome, then assess it against the new binding. Do not relabel old work or admit a stale proposal as though it used the new method.
Work in review or already issued	Preserve its exact version. Create a successor or reconsideration item where the applicable change requires different work. A setting cannot fabricate or erase an approval.
Current access restriction or recalled method/skill	Block affected new dispatch, disclosure and transitions at their enforcement boundary. Reconcile dispatched effects. Pinning never defeats revocation or lets a knowingly invalid method continue.

The system derives the impact of an edit: presentation, optional guidance, criteria/analysis, evidence or review requirements. Uncertain semantic changes are treated as potentially material to dependent work; that classification does not add an Admin approval process. Review of a materially changed recurring Check is separately governed by §4.4.

3.4 Context and memory

Methodology, installed skills, working knowledge and evidence have different standing. Methodology supplies configured requirements. A skill supplies a technique. Working knowledge supplies scoped

facts, preferences, prior work and decisions. Evidence supplies the inspectable basis. None can grant integration access, prove completeness by assertion or manufacture human review.

Skills are used from the first task. Each installed version has an immutable manifest: purpose/applicability, expected inputs/outputs, compatible methodology requirements, requested tool/effect classes, resource/script digests, trust/source and availability scope. Admin installs/enables or edits and saves it. The task filters available skills by scope/capabilities, selects relevant techniques and loads their instructions/resources on demand. It records why and which version: "Using population completeness checks v3." An auditor can explicitly choose a skill or override optional advice without making skill selection a pre-task requirement.

A skill's script runs through normal isolated analysis, with admitted inputs, limits and registered outputs. A requested tool is not permission to use it. A retrieved file named `SKILL.md` remains source content unless deliberately installed through the trusted catalog. Disabling a skill stops new selection; recalling a faulty version also blocks further use and marks dependent work for assessment. Neither action erases past results.

Working knowledge is useful without memory-acceptance paperwork. Record explicit direction immediately as an attributable decision: "Use the contractual termination date." Record source-backed facts automatically with their source and certainty; a user's assertion remains an assertion until supported. Learn low-risk presentation preferences with visible undo. Material conflicts generate a focused question, not approval cards for every fact. Reuse across engagements requires explicit eligible scope, current access and period applicability; client content never becomes a general firm preference through summarisation.

The task's **What Zobba is using** view exposes method/skill versions, key decisions, relevant remembered facts, sources, unresolved questions and limitations. People can correct, exclude, update or forget eligible items. Keep task state, reusable knowledge and acquired evidence conceptually distinct, even when they share PostgreSQL. A citation resolves to registered evidence, not merely to a memory summary.

Each context fragment records kind, source/message/configuration identity and location, version, organisation/client/engagement/user scope, sensitivity, effective period, acquisition time, verification/confidence, dependencies and validity. The invocation manifest records what was included and what access, freshness or budget excluded. Personal preferences, firm method, client facts and engagement knowledge retain their distinct scopes.

Retrieval applies scope/access/applicability filters before lexical/vector ranking, validates returned source locations, and rechecks disclosure at dispatch. A stale or incomplete index can trigger direct-source acquisition; an empty search is not proof of absence. Freshness is source-specific: a current organisation chart and a historic policy have different validity rules. Conflicting sources remain visible; newest does not automatically win.

Longer work is compacted into an inspectable checkpoint with a source manifest. Exact decisions, unresolved operations, questions and review states rehydrate from durable records. The summary is derived context, not new authority. Corrections invalidate dependent claims and context. Revocation invalidates extracts, embeddings, previews, memories, summaries and pending disclosures; restricted historical evidence may remain under retention without being available to the current model/user. Protected sign-in material never enters working knowledge. These mechanisms support long first tasks and reconnect, not a later optional memory feature.

4. Work products, evidence and continuing assurance

4.1 The audit record

Keep four facts separate:

Dimension	Examples
Execution and effect	Completed; refused; interrupted; external outcome unknown.
Input quality and coverage	Complete population; sampled population; missing period; inconsistent source; unverified extraction.
Audit conclusion	No exception found under stated criteria; exception; design gap; hypothesis; inconclusive.
Human review and issuance	Draft; in review; changes requested; approved; issued; superseded.

A model may complete a task whose evidence is incomplete. A complete population may contain an exception. A correct calculation is not a human approval. Normal reading leads with the conclusion and the material limitation, with the other dimensions available without four competing status dashboards.

The lineage is **source** → **acquired evidence** → **extraction/analysis** → **claim** → **work product version** → **review/issued package**. Evidence is immutable once registered. Derived data and annotations are new objects. Record the original bytes, acquisition source/account/time, source version where available, selection/query, content hash and known coverage. Hashes prove byte identity; they do not prove that a source was truthful or complete.

For spreadsheets, preserve sheets, formulas, cached values, row/cell references and transformation rules. For scanned documents, preserve the original and OCR coordinates/confidence. Embedded images are inspectable evidence, not discarded decoration. Scripts record their inputs, environment, parameters and outputs. Large populations use streaming acquisition, columnar files and query engines; bounded UI/model previews never stand in for the full population.

4.2 Editing and reviewing

Use an internal structured document with stable block/table/claim identifiers and a template mapping. Render a document view with anchored comments, citations and a typographic diff. Produce DOCX, PDF and XLSX outputs from versioned content and tested templates. Keep the original imported file alongside its normalised representation.

Do not promise lossless round-tripping of arbitrary Office files. General reading, analysis and templated exports work in the standard profile. Macro-enabled workbooks, precise Excel recalculation and exact Word layout use the licensed Windows/Office profile or remain explicitly unsupported for that task.

An auditor's direct edit creates a version. A stale concurrent edit must be rebased or resolved, not overwrite another person's work. Independent sections may merge when their dependencies remain valid. An issued version and its evidence manifest are immutable; corrections create a successor with a reason, changed claims and a new review. Review is bound to the exact content and required supporting versions.

The workspace journey remains **claim** → **citation** → **preview** → **full evidence** → **back to claim**. Show readable source identity first. Keep the originating claim selected and restore keyboard focus on return. Every export includes the relevant limitations and human preparation/review information; interface overlays are not accidentally exported.

Review, approval and issue are distinct recorded facts but need not be three ceremonies. By default an eligible manager uses **Review and approve** on the exact submitted version; **Issue** is a separate action with recipients and an export manifest. A firm can configure a separate approver where required. The independence check uses the human contributor set: a manager who materially prepared or changed that version cannot independently review it. Accepting responsibility for agent-prepared work makes the human its preparer; a second model never supplies independent human review.

In Admin-configured solo mode, the eligible practitioner uses **Self-review and approve** and then **Issue**. The record and export name the preparer and say **"Self-reviewed by [name]; no independent review."** An engagement requiring independent review cannot silently fall back to solo when a reviewer is unavailable. This supports solo work honestly without implying that self-review satisfies an external independence requirement.

4.3 Concrete audit evaluation

The task develops an inspectable **assessment basis**: the question, criterion and authoritative source, period, population/selection, required evidence, analytical method and reporting limits. It proposes this through conversation while useful discovery continues. Only material ambiguity or a consequential scope/method choice requires an answer. This is a versioned assessment mechanism beneath the continuing Task, not a procedure Builder or another execution compiler.

Record	What it fixes
Criterion version	Readable assertion; exact authority/source/location; effective period and scope; applicability test; required typed facts; calculation or judgment rubric; missing/ambiguous-input treatment; rating/materiality and review rules.
Assessment-basis version	Objective, criteria, period/as-of, source contracts, population/sample manifest, method/environment versions, limitations and attributable material choices.

Record	What it fixes
Fact observation	Subject, typed value or explicit unavailable/ambiguous state, source snapshot/locator, effective/observed/acquired times and extraction/transformation dependencies.
Evaluation revision	Subject and criterion opportunity, basis and input versions, applicability, execution, verdict when valid, reason, assessor provenance and human disposition. Immutable revisions preserve corrections.
Assessment-summary version	Exact evaluations included, coverage metrics and units, distinct affected subjects, limitations, aggregation rule, findings and review state.
Finding and occurrence	Continuing issue identity, each period's supported observation, evidence, importance, responsibility, response and follow-up.

Facts use exact identifiers, Boolean/enum values, dates or time-zone-aware timestamps, decimals with unit/currency, and bounded relations. Preserve leading-zero IDs. Record conversion and matching rules; do not silently compare currencies or use acquisition date to select a policy that applied at transaction time.

Deterministic evaluation uses small pure Rust predicates for exact comparisons, dates, sets and reconciliations, and isolated versioned programs for larger/custom analysis. Record input, program/environment digests, parameters and output. These functions do not drive applications or own Task state. **Judgment-assisted evaluation** uses an explicit rubric with supporting and contrary evidence, stores the actual model invocation and an attributed proposal/rationale, and follows the required human disposition. **Human judgment** records the accountable person's rationale and references. Composite evaluations name their deterministic and judgment components. Model confidence never proves source completeness or substitutes for review.

The durable fields stay separate:

Field	Semantics
Applicability	Applicable, not applicable, or unknown. A supported exemption is not a pass.
Evaluation execution	Not started, waiting, completed, failed or cancelled. A calculation error is an execution failure.

Field	Semantics
Criterion verdict	Met, not met, undetermined, or absent when no valid assessment exists. Only applicable, supported evaluations can be met/not met.
Origin	Deterministic, model proposal, human, or a referenced composite. Unevaluated is a result/state, never an origin.
Human disposition	Unreviewed, accepted, replaced or needs reconsideration, attached to the exact revision. Approval/issuance remains a separate work-product lifecycle.

Reason codes distinguish unavailable source, incomplete population, ambiguous identity, conflicting policy, stale evidence, missing fact, unknown applicability and verified absence. People see a concrete explanation. A complete authoritative approval history containing no required approval can establish a failure. A timeout or a missing permission establishes unavailable evidence. A crashed evaluator produces no new valid verdict; its earlier result remains historical/stale. Known local exceptions remain supported even when the wider conclusion is inconclusive.

Coverage is recorded at the right grain. A population manifest names the unit, period/query, source identity, acquired snapshots, pagination/end-of-stream proof, source-to-acquisition reconciliation, duplicates, selection and exclusions. “Retrieved 1,000 rows” alone does not prove a population of 1,000 subjects. Preserve mappings among received rows, resolved subjects, in-scope/excluded/scope-unknown subjects, selected subjects, applicable/not-applicable/unknown criterion opportunities, and evaluated/pending/failed opportunities. A partition must use one grain; failures across criteria cannot be summed and called exception records.

Every reported metric has scope, unit, calculation and known/bounded/unknown denominator. Show counts and limitations before percentages. An unknown population count is not zero; a bounded preview is not the population; an incomplete acquired set supports claims about inspected records, not a population-wide rate. If the population is known but assessments are incomplete, report known exceptions as a lower bound with unresolved counts. A verified empty eligible population says **“No eligible items; operating effectiveness was not demonstrated”**, unless the methodology defines another explicit no-activity disposition.

For a sample, preserve the population frame, purpose/unit, selection method, strata, size, seed or selected identities, substitutions/exclusions and justification. Statistical inference requires a validated pinned method and recorded assumptions/confidence/tolerance. A judgmental sample does not acquire statistical confidence merely because a model supplies a percentage.

Aggregation follows the methodology but cannot discard these facts. An unqualified **“No exception found”** needs resolved applicable assessments and adequate coverage for the claimed scope. Supported failures produce exceptions; unresolved material evidence limits the wider conclusion. A method may report **“Exceptions found; overall assessment inconclusive”**. Completion, evidence quality, assessment and human approval remain independently visible.

A person may accept a proposal, request work, correct facts/basis or replace professional judgment with reasons. The original proposal and facts remain. Corrected facts cause recalculation; changed

interpretation causes a new criterion/basis or human assessment revision. An allowed waiver is a visible disposition with authority/rationale, not a rewritten arithmetic result. It cannot erase unavailable inputs or inflate coverage. Review binds the work-product version, summary, evaluations, basis and required evidence; material changes mark affected dependencies for reconsideration.

4.4 From investigation to recurring Check

“Run this each month” proposes one readable Check from the completed work. It freezes its **assurance method**, while navigation and bounded investigation remain adaptive. The Check uses the same Rust Task engine, operations, computer, evidence and review model.

Check contract	Bound content
Assertion and basis	Objective/scope, criteria and effective-policy selector, rating/aggregation rules, source Task and assessment basis.
Source and population	Canonical provider/tenant/account/system/resource, period selector, schema/meaning/freshness/completeness rules, matching/duplicate rules, full-population or pinned sample method.
Evaluation	Exact deterministic program/environment and rubric versions, required facts, admissible adaptive retrieval, qualified model-routing profile and uncertainty treatment.
Outputs and review	Templates, coverage measures, finding identity, limitations, eligible team/solo reviewer and issuance rules.
Authority and capacity	Narrow standing Permissions, revocable service delegation, accountable owner, action/purpose limits, budget and escalation destination.
Continuation	IANA time zone, calendar period/as-of, schedule or source-event window, waiting deadline, overlap, catch-up and notification rules.

Draft edits save normally. Activation records review/approval of the exact assurance definition under the applicable team or labelled solo rule; review and activation can be one action. A schedule alone does not grant unattended authority. Each occurrence binds its Check version, period, actual source snapshots/account, current narrowed authority, method/routing versions and budget before work. Recheck authority at dispatch. Approved method pins preserve interpretation, not revoked access.

The recurring result is an automated **draft assessment**, never a fabricated human sign-off. Permitted notifications and routine coordination proceed under standing Permissions. An operation marked Asks first creates a durable decision wait for the responsible person; no effect is dispatched and independent work can continue. A Check can investigate related exceptions inside its declared scope/budget. Exploratory leads outside the frozen assertion are labelled separately and proposed for follow-up.

Change	Treatment
Same-account token refresh, credential rotation, replacement computer, changed browser layout	Record operational rebinding, revalidate and continue within the same method.
New period file selected by the approved rule, harmless extra column	Validate period/identity/coverage and the declared compatibility rule; bind the exact source version.
Spelling, display metadata, compatible formatting/guidance that does not change criteria, selection, analysis/rubric, coverage or assurance; due time/reminder edits preserving period/scope/budget	Save an attributable maintenance revision. No repeated audit-method approval. Calling advice optional does not make its effect on the method immaterial.
Criterion, source meaning or identity, material analysis/rubric, sample design, mandatory evidence/review rule, wider authority, processing destination or covered-window changes	Withhold affected work and propose a materially revised Check under its existing review rule. Admin's settings save itself remains ordinary configuration.
New underlying policy, recalled method or unqualified model withdrawal	Detect whether it affects the period/assertion. A knowingly inapplicable definition cannot continue solely because it was previously approved. Explain the blocked dependency.

Pin a qualified model set/capability profile and record the actual model. A permitted substitution for navigation or validated extraction can be operational maintenance. A model/rubric change that materially changes judgment requires qualification and the Check's semantic revision. Do not freeze a withdrawn model indefinitely or silently change the assurance.

Occurrence identity belongs to the logical period. Use (check_id, logical_period_key) for a calendar Check, with explicit UTC boundaries and local time-zone/period labels stored. Check and schedule versions are bindings, not duplicate-creation keys. A due-time edit preserves the occurrence. A material window change needs an explicit activation-period mapping; a rerun creates a linked execution/evaluation revision, not another automatic occurrence or send. Event checks deduplicate canonical source object/version and coalesce under their configured business window. Ad hoc tests are visibly separate and do not satisfy a scheduled period accidentally.

Default to one active occurrence per Check, including evidence/decision waits. Waits release compute but keep the logical slot. Later due periods are recorded as delayed, not silently collapsed. The default waiting deadline is the next due time, or 24 hours for event-only Checks without a next due time: close the older assessment with known results and limitations, then admit the next. Expire its pending decisions and prohibit further dispatch against them. Late answers/evidence require a newly admitted scoped correction, not silent reopening. Already-dispatched uncertain effects continue reconciliation

under their original receipts; closing an assessment does not resolve them, release conflicting resource claims or authorise a retry. A configured bounded overlap/deadline can differ.

Monthly defaults cover the previous complete calendar month in the firm’s time zone. A skipped daylight-saving time runs at the next valid local instant; a repeated time runs once at its first occurrence. Store the resolved instant and rule. Record every missed period after downtime. Automatically catch up only the latest within the configured lateness window; older periods remain Not run unless an existing bounded backfill rule or one explicit batch decision covers them. The batch states periods, historical/effective methods, source availability, budget and concurrency. Today’s policy must not silently replace the historical one.

Persistent issues are separate from their period observations. Identity uses scoped criterion lineage, canonical subject/system and issue kind; compare those fields before merging, rather than relying solely on a digest or fuzzy model match. Results show new, continuing, changed, resolved or reopened issues, with each occurrence’s evidence retained. Not observed this period is not proof of remediation; closure needs follow-up evidence or an accountable disposition. This prevents repeat notifications from becoming duplicate findings.

4.5 Evidence arrival and a worked assessment

An evidence request has identity, owner, expected content/period, permitted locations, due/reminder rules and a sufficiency condition. Track **requested** → **received** → **checked** → **sufficient/partially sufficient** → **fulfilled** with the supporting facts; rejected/wrong-period material stays visible. A supplier’s “done” message is not fulfillment. Webhooks are hints: reacquire the exact object, verify access/version, assess its content, then resume the linked waiting Task. A duplicate arrival does not cause another send or another occurrence. Evidence arriving after review/issue creates a successor or follow-up with reconsideration of affected claims.

For example, the auditor asks: **“Review August supplier payments above ZMW 50,000 against our approval policy, investigate exceptions and prepare the working paper.”** The currency, threshold and criteria here are illustrative firm rules. Zobba binds the effective policy and two criteria: approval before release, and an approver authorised at that time. It uses API acquisition and analysis for the population, and the real browser to investigate supporting application records. Relevant method/skill/working-knowledge versions appear from the start.

The source manifest reconciles 1,250 unique acquired payments: 50 outside August, 1,200 in-period, 200 at/below the threshold and **1,000 applicable payments**. Approval history is unavailable for 20 of those payments.

Criterion	Met	Not met	Undetermined	Applicable payments
Approval before release	965	15	20	1,000
Authorised approver	968	12	20	1,000

Seven payments fail both tests: **27 failed criterion opportunities represent 20 distinct exception payments**. The same 20 payments are undetermined on both criteria; the remaining 960 meet both. The result says:

I found supported approval exceptions in 20 of 1,000 applicable payments. Seven had both issues. I could not assess 20 other payments because their approval history was unavailable; the remaining 960 met both tests. The exceptions are supported, but the overall assessment remains limited. The paper and missing-history request are ready for review.

Selecting an exception opens the criterion, payment/approval times, effective role evidence, exact calculation and evaluation revision. Supplying valid delegated-authority evidence creates a new fact/basis and recomputes affected results, preserving the original. Team review uses a different eligible manager; solo review bears its explicit label. Promoting this work pins the assertion, method and source contracts; next month's browser navigation can differ. The next occurrence applies the same meaning to new evidence and carries continuing issues forward.

Notifications name decisions, blocked access, completed results, material new exceptions or budget limits. Routine tool chatter stays in the Task. External notifications use permitted destinations, a safe summary and an authenticated link, with no unapproved disclosure of evidence or client details.

5. Target architecture

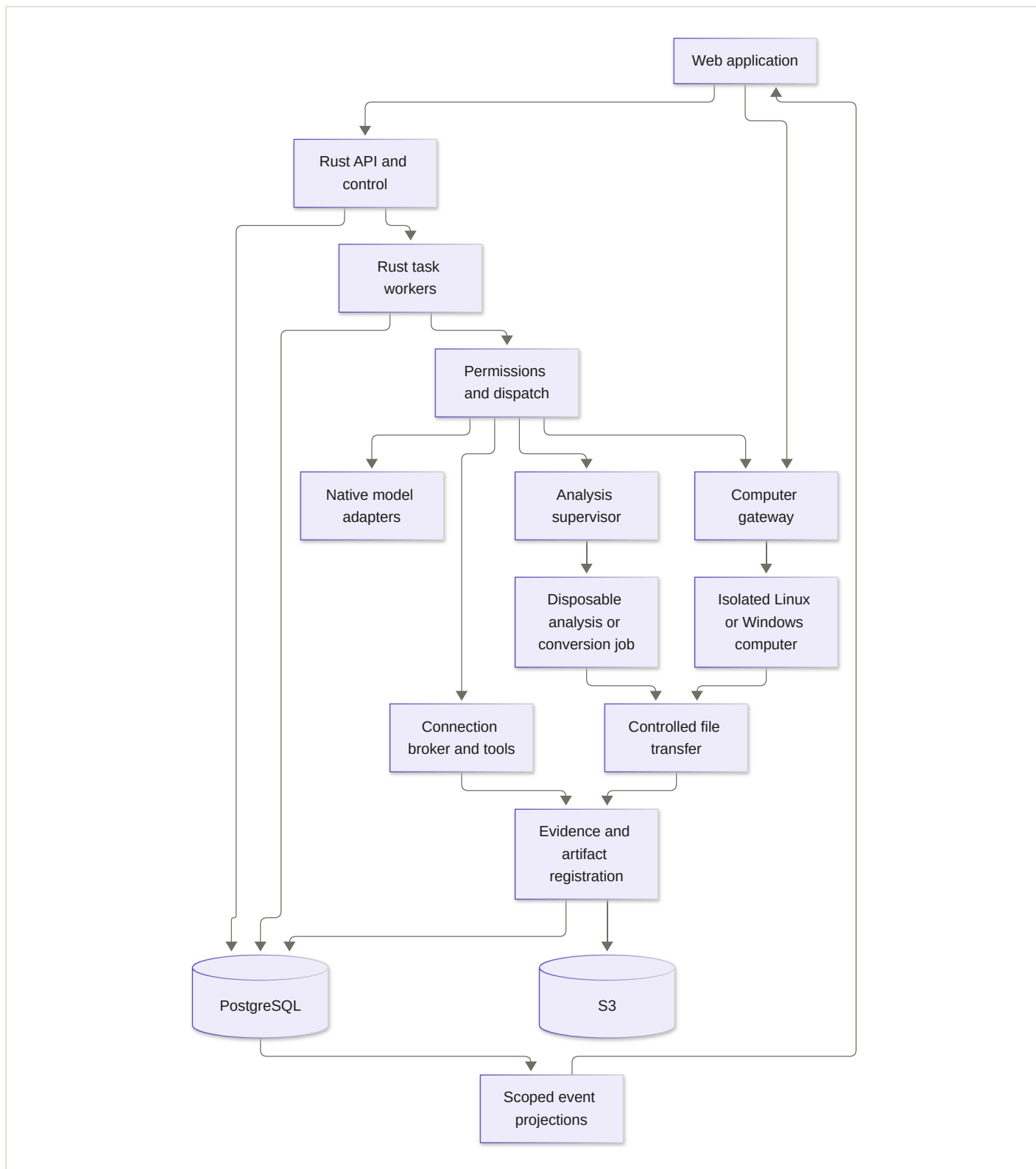
5.1 Stack and deployment boundaries

Use one Rust application codebase with explicit modules and two application deployments: an API/control process and task workers. They share the same domain commands and transaction rules. Execution environments are separate because they have different privileges and resource lifecycles, not because every domain concept needs a service.

Layer	Recommended choice	Reason
Web	React, TypeScript and Vite; typed HTTP client, resumable event stream and dedicated computer connection.	Retain useful React/Pair components while removing Next server actions and Node backend authority. The authenticated product does not need a second server-side domain implementation.
Application backend	Rust, Axum, Tokio, Serde, SQLx; HTTP/JSON with generated OpenAPI contracts.	One backend language and domain owner. Tokio handles bounded asynchronous work; explicit types express states and receipts.
Identity	Amazon Cognito as OIDC identity provider; enterprise federation when required. Rust owns secure server sessions and current application authorisation.	Avoid rebuilding password/MFA/SSO machinery or retaining Better Auth as a permanent Node bridge. Identity-provider groups are not the audit role authority.
State and durable work	Managed PostgreSQL 18; relational aggregates, append-only events/receipts, transactional inbox/outbox and leased work tables.	Atomically commit accepted work and its wakeup. No pg-boss internals, Redis queue or second workflow authority.
Files and evidence	S3 with versioning, KMS encryption, retention policy and protected issued manifests.	Large binary objects remain separate from relational state, with hashes and scoped access. Object retention follows firm/legal requirements; it is not universally fixed at seven years.

Layer	Recommended choice	Reason
Search and retrieval	PostgreSQL full-text search and pgvector with scoped metadata; object store holds original/extracted material.	A sufficient first architecture without a separate vector service. Re-evaluate only against measured index/workload requirements.
Application hosting	AWS ECS/Fargate for API and task workers; RDS Multi-AZ, S3, KMS, Secrets Manager and CloudWatch/OpenTelemetry.	Managed operations and a small number of application boundaries. Private networking separates data and execution planes.
Computers	Dedicated, disposable EC2 computer instances with encrypted EBS; Linux baseline and a qualified Windows profile.	A real OS environment and hypervisor boundary for credential-bearing application sessions.
Analysis and conversion	Per-job Fargate isolation, non-root workloads, immutable images, ephemeral encrypted working storage and no general egress.	Model-authored programs and hostile documents stay outside the application and credential computer.
Browser/document tools	Playwright Node sidecar, vetted document/OCR tools, Python, DuckDB/Polars and LibreOffice where appropriate.	Use mature tool ecosystems behind narrow execution ports; these tools do not own task state.

Recommend one primary deployment region for each organisation's data. Select the region during onboarding according to data location and available provider destinations. The firm controls permitted model/connector processing locations separately: storing S3 objects in a region does not keep provider requests there. Private/customer-hosted installations remain an architectural extension, not a simultaneous first operating model.



Design diagram 2

Model/connector dispatch, computer access and object access have different scoped credentials. The diagram's arrows are ports, not blanket network permission between every component.

5.2 Rust module ownership

Module	Owns
Identity and scope	Server sessions, organisations, clients, engagement membership and current assignments.
Task authority	Task revisions, accepted commands, work cycles, decisions, owner leases, delegated tasks and termination.
Agent runtime	Context-to-model loop, proposed work, child execution, progress and bounded scheduling inside current authority.
Permissions	Purpose/account/resource classification, policy versions, action decisions and dispatch grants.
Models and context	Native adapters, capability selection, context manifests, compaction and processing-destination checks.
Connections and tools	Canonical tool descriptors, bound accounts, OAuth custody, connector requests and effect reconciliation.
Workspaces	Computer/session identities, profiles, input ownership, lifecycle and supervised analysis specifications.
Evidence and work products	Acquisition receipts, immutable objects, derivations, claims, versions, review, issue and corrections.
Knowledge and methodology	Admin-saved methodology versions, task bindings, validated skill catalog, scoped knowledge and invalidation.
Audit evaluation	Criterion contracts, population/coverage manifests, exact calculations, supported judgments, evaluation revisions and aggregation.
Continuing work	Check definitions, occurrences, evidence subscriptions, reminders, budgets and notifications.

Module	Owns
Delivery and operations	Read projections, event cursors, telemetry, costs and administrative diagnostics.

Do not implement each row as a network service. The computer gateway/supervisor and disposable execution processes are justified trust boundaries. The connection broker can initially be a restricted worker process from the same Rust repository, with separate cloud identity and egress. Evidence metadata and task state remain within one PostgreSQL transaction boundary where the operation permits it.

5.3 The durable model

Use a fresh schema. Its main record groups are:

Records	Important relationship
Organisation, client, engagement, membership, assignment	Every client-bound record has explicit scope; IDs select records, never grant access.
Task, work cycle, command, decision, task event	Commands have client idempotency keys and accepted/applied receipts. One task revision order binds them.
Operation, attempt, dispatch claim, receipt, reconciliation	A provider call ID is metadata, not the business operation identity. One operation may have several attempts without implying several effects.
Connection, capability, policy revision, delegation	Bound to actual account/system, operating purpose, permitted action/resource and expiry.
Workspace, generation, input lease, transfer receipt	A durable workspace identity can outlive several machine instances; commands bind the current generation.
Evidence object, acquisition, extraction, analysis, claim	Source bytes and derived outputs remain independently attributable.
Methodology version, skill version, task binding, knowledge revision	The work records which requirements, techniques and scoped facts informed it; configuration changes never rewrite that history.
Criterion version, population manifest, evaluation revision, disposition	The result binds its subject, method, inputs, coverage, origin and evidence; a human change is a new attributable revision.

Records	Important relationship
Work product, version, review, issued manifest	Approval applies to a version and its dependencies, not a mutable document title.
Context fragment, manifest, checkpoint, memory	Each derived item has source lineage, scope and validity.
Check definition/version, occurrence, subscription, notification, recurring issue	A definition pins its semantic method; duplicate triggers resolve to one occurrence, and repeated exceptions link to their continuing issue.
Durable work, resource claim, budget reservation, outbox	Wakeups and resource accounting are committed with the work they represent.

Use ordinary relational state plus an append-only event/receipt ledger. Full event sourcing would add replay and schema-evolution work without making external effects transactional. Keep database constraints for unique occurrence keys, command deduplication, valid version references and review transitions.

RLS provides a second scope barrier on tenant/client/engagement records. Application principals use non-owner database roles with forced policies where applicable, transaction-local scope, bounded queries and tested pooled-connection reset. Runtime and background principals receive explicit scopes; they do not casually bypass RLS. Cross-scope foreign-key checks, scoped object paths and reauthorised downloads close the gaps that table policies alone cannot cover.

5.4 One authority, responsive control

“One task owner” means one domain authority and one valid execution coordinator, not an actor process that must be kept alive forever. The Rust Task module owns all transitions. API admission and workers invoke those same commands through PostgreSQL revision/epoch checks.

The API transaction validates current identity, records a command and its durable acknowledgement, and adds a wakeup. The execution worker acquires a time-bounded owner lease with a monotonically increasing epoch. It reconstructs the task and advances it through short transactions. A wakeup is permission to inspect pending work, not permission to replay the last external action.

Urgent controls use a priority path within that same authority. Task Pause/Stop advances the task execution epoch and withholds new dispatch grants. A computer transfer advances that workspace’s input/observation epochs; it does not freeze unrelated analysis. Guidance has a separate intent revision. These operations do not wait behind a model response. Executors and gateways observe revocation and return acknowledgements. A stale worker cannot commit a new proposal or consume a new dispatch claim under an old epoch.

The system cannot atomically commit PostgreSQL and an arbitrary remote action. The gateway atomically consumes a one-use dispatch claim under the current epoch before I/O; that commit is the authorisation cutoff. The operation is now possibly dispatched even if a crash happens before bytes leave. Revocation prevents subsequent claim consumption and requests cancellation of existing claims. The gateway alone may perform I/O, with no worker bypass. Reconcile anything that crossed the cutoff; do not imply an impossible atomic check-and-send or retroactive cancellation.

5.5 Durable queue and budgets

Use a PostgreSQL-backed work table with unique wakeup identity, due time, priority, attempt count, lease owner/expiry and fencing epoch. Claim eligible rows in short transactions with SKIP LOCKED. LISTEN/NOTIFY accelerates wakeups; polling recovers missed notifications. A transactional outbox handles external notifications and trigger delivery.

Keep task ordering and resource admission separate. Schedule fairly across organisations and engagements, with weighted priority for interactive controls. Bound active tasks, helpers, model requests, connector requests, computers, analysis jobs, database pool use and output bytes independently. Release database connections and general coordinator capacity while waiting. Retain the relevant in-flight model/connector permit and budget reservation until completion, confirmed cancellation or expiry. A human/evidence wait releases execution capacity entirely.

Reserve budgets before expensive work and settle against measured usage. Unknown provider charges remain reserved until reconciled or explicitly estimated. A task nearing its ceiling explains what remains and asks for an extension when needed. Waiting and notification subscriptions do not require a permanently running computer.

6. Engine, models and tools

6.1 The engine's loop

Each work cycle loads the current Task and unapplied commands, determines the useful next work, assembles authorised context, requests a model response and validates complete proposals. It records admitted operations before dispatch. Results become durable observations and evidence references, then feed the next cycle.

A Working brief is revisable planning information. Tool proposals are untrusted requests. The runtime, Permissions module and executor contracts determine what can run. The model does not execute tools directly, write the audit ledger or decide whether a timeout proves an action failed.

Long provider streams and tool calls run as cancellable children of the coordinator. UI questions and controls remain independent. New guidance increments the task's intent revision. A response produced against an older revision cannot silently drive contradictory work: retain useful observations, rebase the proposal and regenerate where necessary. Record which command was consumed and when.

6.2 Native model interface and selection

Own a portable model representation:

- **Input:** attributed messages, selected evidence/media references, current Working brief, typed decisions, tool descriptor snapshot, capability requirements and budget.
- **Stream events:** text delta, complete tool proposal, structured answer, refusal, usage, completion and classified error.
- **Invocation identity:** task/cycle/attempt, provider, requested and actual model, effort, context manifest, destination and permission generation.

Implement native OpenAI Responses and Anthropic Messages adapters first. Their streaming, images, tool results, continuation and error handling differ; do not force everything through a fake OpenAI-compatible wire format. Admit tool calls only after complete arguments pass size, schema and semantic checks. A partial stream is never executable authority.

Use an Admin-approved default routing profile. A capable general model leads the task; a suitable vision model handles computer perception; extraction/classification may use smaller permitted models; analysis is performed in code. A second model can challenge a consequential claim, but that remains model assistance, not human independent review. Select exact model IDs from an administrator-controlled catalog based on capability and destination, rather than baking screenshot marketing names into the product.

Auditors can inspect and select allowed model/effort settings. Automatic routing is bounded by the displayed profile. Never silently switch processing destination, lose image support or lower a required capability. Switch providers between committed cycles, reconstructing from portable history and committed operations. Do not retry completed tool effects as part of a provider switch.

Provider continuation tokens are optional, short-lived optimisation. Bind them to task, provider/model, context manifest and permission generation. Drop them on relevant revocation, provider change or an

inconsistent prefix. Authorised durable context must be enough to continue without them.

6.3 Context construction and invalidation

Assemble context in this order: enforced task/operating constraints; the bound methodology and necessary skill contracts; objective and accepted decisions; unresolved questions/operations; recent conversation; relevant authorised working knowledge; selected evidence and analyses; optional supporting skills/preferences. Required method instructions and the provenance of a fact cannot be discarded merely to fit more conversation. This is a construction policy, not an instruction hierarchy that lets an optional skill overrule a person.

Budget text, images, tool descriptions and output independently. Large files are registered and queried through references. Compaction records the covered event range, source versions, preserved decisions, uncertainty and omissions. Validate that all unresolved durable facts are represented. Refresh stale context before continuing.

Every outbound model request passes a disclosure check after asynchronous assembly, immediately before sending. If a source was revoked, invalidate any dependent fragment or summary that cannot be safely separated and rebuild. Do the same for embeddings, memory, cached previews and opaque continuation. Historical retained evidence can remain restricted in storage without being available to the model or current viewer.

Apply the matching rule on return: an in-flight result received after revocation may be retained under narrow receipt authority, but cannot automatically stream to a viewer, enter memory, update a work product or feed the next model cycle. Reauthorise active subscriptions, projections and pending output when the access generation changes.

6.4 Tool contracts

A trusted tool descriptor contains canonical identity/version, exact input/output schemas, required scopes, account binding, resource selector, operating purpose, effect class, limits, idempotency support, cancellation semantics and reconciliation method. Register output-size and completeness rules as well as a pretty description.

The model sees a task-specific tool catalog. A hidden or guessed tool name still cannot execute without an admitted handle. MCP read-only/destructive annotations are advisory metadata; they do not override Zobba's action classification. Reject name collisions after normalisation and parameter rewrites that change the reviewed operation.

Prepare a call by resolving the current account, canonical effective parameters, tool/catalog revision, applicable decision, scope and resource claims. Persist that binding. The gateway rechecks current task and permission epochs at dispatch. A refreshed connection must not silently reroute an operation to a different account.

Prefer direct APIs for stable, bulk operations and authoritative receipts. Use vetted MCP adapters where their account and action boundaries are understood. Use browser/desktop tools when that is the suitable available interface. These transports share the same Permissions semantics.

Connection family	Recommended integration surface
OneDrive, SharePoint, Outlook, Microsoft calendars	Native Microsoft Graph adapters, scoped OAuth and delta/webhook cursors; browser for unsupported application surfaces.
Google Drive, Gmail, Google Calendar	Native Google APIs with account-scoped OAuth, restricted scopes and provider-specific change/watch handling.
GitHub	GitHub App installation where suitable, with selected repositories and explicit read/write tool separation.
Todoist and similar task tools	Vetted API or MCP adapter with stable task/project identity and deduplicated operations.
Business applications	Native read adapter where available; otherwise a qualified browser/desktop profile with verified environment/account.
Uploaded/local working files	Scoped file handles and selected mounts; no arbitrary application-host filesystem paths.

Treat provider notifications as untrusted wakeups. Renew subscriptions, persist cursors, deduplicate delivery and periodically reconcile where notifications can be missed. OAuth refresh tokens stay in the broker's secret store. The model and general analysis job never receive them.

Bind each OAuth attempt to its issuer/provider, initiating user/session, single-use state, PKCE challenge, allowed return destination, expected organisation/account and scopes. The broker exchanges and stores tokens, verifies the returned identity, and attaches the connection only to that identity. Token renewal is operational maintenance within the same binding; an account switch is a recorded rebind. HTTP success or a provider job ID may mean **accepted, still pending**. Only the adapter's declared receipt/status contract can establish a completed effect, and an unavailable source never becomes an authoritative empty result.

Connections explicitly distinguish personal consent from firm-owned service/app consent. Admin controls which kinds and providers are allowed; the account owner completes personal consent, and an authorised firm representative completes organisation consent. A Check receives a narrow, revocable service delegation bound to its connection and purpose. Removing a member, withdrawing consent or disabling a connection invalidates dependent execution. A new owner or service account requires an attributable rebind and verification of source access; it never silently inherits the departed person's identity. Organisation account policy, enterprise consent and supported sign-in must be qualified in the first customer profile that needs them.

6.5 Delegation and concurrent work

A parent creates child tasks with explicit objective, input snapshot, allowed tools, maximum budget and result contract. Delegated authority is an intersection, never a copy of all parent credentials. Results commit independently and join through durable receipts; presentation order must not delay saving a completed result.

Bind every child operation to its delegation lineage and current ancestor authority generations. A child epoch alone is insufficient. Parent Stop revokes descendant dispatch and requests cancellation throughout the tree, while retaining attributable late receipts. Parent Pause quiesces descendants unless the user explicitly pauses a narrower branch. Revocation and exhausted aggregate budgets propagate through the same lineage checks. A computer takeover remains scoped to that computer and dependent work.

One actual application session has one exclusive input lease across all tasks and helpers. Multiple reads are parallel-safe only if their contract says so: a read may advance a cursor, change browser state or observe a changing source. Use a common acquired snapshot where consistency matters. Work product writes require an expected base version; safe section merges still recheck claim/evidence dependencies.

7. Computers, analysis and credential custody

7.1 Concrete computer platform

The baseline computer is a per-workspace EC2 instance running Ubuntu 24.04, a minimal desktop, Chromium, managed browser driver and supported file/document tools. Use **m6i.large, 2 vCPU/8 GiB** as the initial Linux capacity allocation and **m6i.xlarge, 4 vCPU/16 GiB** for Windows. These sizes require workload qualification; large analytical jobs belong in separate analysis. The VM is exclusively assigned to a workspace, using ordinary EC2 shared tenancy, not the differently priced Dedicated Host product. It has an encrypted EBS working volume, no public inbound administration, tightly scoped egress and no application database credentials. Provision from a verified, versioned image; record instance/image/workspace/generation before admitting it.

Use the Apache Guacamole JavaScript client and guacd for actual VNC/Linux and RDP/Windows display over authenticated WSS on port 443. The Rust gateway authorises attachments; a small trusted local computer adapter enforces the final input epoch. Route human key/pointer actions through the separate authorised input channel to that adapter, alongside agent Playwright/desktop actions. Reject raw key/pointer, clipboard and file-transfer opcodes on viewer tunnels while retaining the required display/synchronisation protocol. This prevents buffered RDP/VNC input from bypassing generation checks. Windows input runs in the selected interactive user session; it does not silently bypass UAC or control the secure desktop. Elevated applications require a qualified profile.

Authorised viewers join the same underlying desktop connection. Starting a separate RDP desktop for each viewer would show the wrong environment. A Guacamole connection ID is not access authority; attachments require short-lived gateway capabilities and current scope. Keep guacd and machine ports private and verify host identities.

Use private computers and same-AZ gateway/egress paths where possible. Controlled browser internet requests traverse a policy egress proxy/NAT; display delivery goes through the gateway/public ALB, not NAT. S3 uses a gateway endpoint where appropriate. Separate credentials, cloud identities and egress by function. Regional gateway replicas share capacity across customers but never authorise a cross-scope session. Scale on measured concurrent display/CPU/memory/queue load, not merely task count.

This keeps the lead AWS architecture. The alternate's Fly/Firecracker proposal does not establish subsecond restoration of a signed-in desktop: current Fly documentation discourages suspend above 2 GB and requires handling cold starts. An owned-host cost crossover cannot be inferred from a per-tenant hour count. If Guacamole misses the response targets after normal tuning, a WebRTC media implementation can be evaluated behind these same authority/session contracts; transport does not change the product or create new authority.

Default to one task computer with one scoped account set. A helper needing independent computer interaction receives a separate isolated workspace. Do not pool authenticated profiles across clients or engagements. Reuse compute only after destructive sanitisation or reprovisioning from a clean image.

Expose vetted browser/desktop actions through the local adapter, not a general shell or unrestricted CDP endpoint to the model. Credential storage, browser profiles and machine administration stay behind trusted adapters. Model-authored programs run in the separate analysis environment with explicitly selected files.

7.2 Supported application profiles

Profile	Support promise and limit
Standard Linux/browser	Managed Chromium, web business applications, PDFs/images, CSV/Parquet, ordinary Office reading and templated exports. Qualify target sign-in and automation behaviour.
Windows desktop	Windows Server 2022 on EC2 with RDP, approved application images and stronger startup/cost controls. Needed for qualified Windows-only applications and native Office scenarios.
Native Office	Office LTSC Standard 2024 through AWS License Manager named-user subscriptions, RDS SAL and AWS Managed Microsoft AD. Qualify Professional Plus for applications such as Access when needed. This does not imply Microsoft 365 feature parity or unattended automation entitlement.
Customer-private connection	Later deployment profile using approved private network routes and the same broker/workspace contracts. Do not install ad hoc VPN clients inside task machines.

Windows is part of the target product, with an explicit application support list and commercial profile. Its licensing and directory footprint is materially larger than Linux. Validate the right to use a particular application unattended and its supported automation behaviour before enabling unsupervised work, including continuation after the auditor leaves as well as schedules. Interactive Office licensing alone is not proof that unattended Office automation is licensed or reliable.

Give each organisation's Windows profile its own registered Managed AD in its own VPC, with scoped named-user bindings; do not share a technical Office user across a firm or a directory across unrelated firms. Reach the regional gateway/authorised application proxy through explicit private routes such as VPC peering. The proxy originates allowed outbound connections; peering does not provide transitive access to another VPC's NAT gateway. Account for charged cross-AZ traffic or any additional routing/endpoints. Pre-enrol and configure the licensed profile when the capability is enabled. AWS documents first domain-join/configuration as taking around 20 minutes; this preparation must not appear as a supposedly instant task handoff. Useful work on available sources can proceed during preparation. Restarting an enrolled computer and enrolling a new one are different readiness cases.

Prefer local-browser OAuth for connectors. Remote application login needs a qualified MFA/device-trust method. Guacamole does not establish generic forwarding of local passkeys, hardware keys, password-manager extensions or enterprise device identity. Unsupported authentication is an access limitation to resolve with the customer, not a reason to collect passwords in chat.

Use file-format libraries and qualified conversion workers for ordinary documents. Offer a native application when the task genuinely needs it. Failed conversion, unsupported macros or unavailable application licensing must be visible task limitations, not quietly approximated calculations.

7.3 Input fencing and live view

Bind each input command to workspace ID, generation, controlling principal, lease epoch and expiry. Validate them at the final input gateway. For pointer actions, also bind the viewport/display geometry and reject stale mappings after resize or reconnect. The human browser never receives a general-purpose machine credential.

A control transfer first stops accepting old-epoch input, releases held keys/buttons and drains or cancels accepted input. Fence the entire high-level driver operation, including Playwright auto-wait/retries and desktop action queues, not just its first click. The local adapter must acknowledge quiescence or be safely torn down before a new human lease is usable. All input, clipboard, observation, capture, upload and download paths participate in the applicable epochs. Late queued commands are rejected; already dispatched effects are reconciled rather than recalled. On gateway loss, leases expire and input closes; the UI shows Reconnecting rather than an apparently live controllable screen.

Live video is transient, separately authorised and bandwidth-bounded. Captured audit evidence is explicitly acquired and registered; a live frame is not automatically an evidential screenshot. Record useful replay intervals where policy allows, preserving gaps and excluding protected sign-in. Replay is a historical view, never a control surface.

Prioritise readable text at a reference 1440×900 desktop, with adaptive resolution/update rate; aim for at least 15 displayed frames/second during ordinary scrolling/dragging under the reference network. Static work need not consume a constant video stream. Bound each viewer’s buffered bytes and age. Do not drop arbitrary incremental Guacamole drawing commands; reduce delivery at a valid boundary or disconnect and resynchronise a slow viewer. Stop display encoding/delivery when nobody watches, while authorised agent work may continue. Model observations and evidence captures remain separate operations. A locally drawn cursor is not confirmation that the remote application accepted an action.

Response targets are acceptance criteria, not measured performance or a sales SLA. The reference network has client-region RTT ≤80 ms, ≤1% loss, ≥10 Mbps down/2 Mbps up. Measure admission, local acknowledgement and browser paint with a representative browser, spreadsheet and PDF while model/analysis work and additional viewers are active.

Journey	Proposed p95 target and boundary
Attach to a running, ready computer	Current useful frame within 2 seconds; existing authentication, no application launch.
Human input → visible remote response	Within 200 ms for ordinary UI actions in the reference network; remote application processing delays measured separately.
Takeover → safely fenced, usable control	Within 1 second for cooperative cancellation. Failed quiescence remains visibly pending/paused, never an early success.

Journey	Proposed p95 target and boundary
Allocate a clean ready Linux spare	Usable desktop within 30 seconds, excluding third-party sign-in. Applies to a pool hit.
Restart stopped, preconfigured Linux	Usable desktop within 90 seconds when capacity/health checks succeed; sign-in can still be required.
Restart enrolled Windows	Usable desktop within 180 seconds; application initialisation recorded separately.
Cold new Linux	Usable desktop within 180 seconds as a target to qualify; honest Preparing status.
Fresh Windows/Office	Enablement preparation, not instant startup; current vendor guidance is around 20 minutes.

Also qualify RTT 150–250 ms, 3/1 Mbps and 1% loss: target ≤ 500 ms visible input response for ordinary actions, with lower display load and an explicit delayed-connection state. Measure frame freshness as well as frame rate. A degraded still-image preview is labelled and does not masquerade as responsive live control. Priority control admission and local lease expiry remain independent of overloaded media/model streams. Region choice must fit users and processing obligations; the US East cost example alone says nothing about their response time.

7.4 Suspend and recover honestly

A task waiting for a person or evidence releases model, worker and analysis capacity. Computer readiness has its own bounded policy:

1. **Prepare when useful.** Once an application need is established, restore its computer while independent acquisition/analysis proceeds. Scheduled work can prepare before its due time. Preparation uses the existing budget and never performs a source write merely to warm a session.
2. **Keep a short ready interval.** Default to ten minutes after relevant activity. Active viewing/control, transfers, admitted actions and unsaved work prevent an unsafe stop. A chat tab alone does not. Offer a bounded Keep ready interval charged to the displayed allowance; uncheckpointable work remains visible and subject to a budget/timeout decision rather than running forever silently.
3. **Stop safely.** Save files/checkpoints, quiesce input, verify recoverability and stop the VM. The baseline retains disk, not RAM. No computer is stopped merely to meet an optimistic cost estimate while doing so would lose acknowledged work.
4. **Pool only clean capacity.** Start with one credential-free Linux spare during 200 staffed hours/month for a regional fleet with at least six active Linux users, and no dedicated spare for a lone user. Refill after assignment. This is an initial budget, not a guaranteed hit rate: prioritise returning sessions and admit bursts fairly within firm concurrency limits, showing queue/preparation state. A spare starts new work; it does not claim to restore another machine's authenticated RAM.
5. **Prepare Windows by named profile.** Predictively start the already enrolled customer's computer. Do not rely on anonymous Office licences or cross-firm authenticated profile reuse.

Set recoverable idle profile retention to seven days initially, adjustable by Admin with explicit sign-out/delete controls and immediate authority revocation. Retained disks and credential-containing snapshots share that boundary. Repeatedly active profiles may last longer; audit evidence follows its separate, usually longer policy. The cost worksheet conservatively retains full-month volumes to show the upper idle-storage case. No reusable pool instance retains prior client data: destroy its volumes and reprovision a clean image before reassignment.

Do not promise that stopping a machine preserves RAM, an unsaved document or a valid application login. Default to restarting from a saved disk/checkpoint and reconnecting or signing in again. A retained provider session or VM hibernation is an optimisation only when the selected profile supports it and its state can be checked.

On recovery, increment the workspace generation, inspect the actual session and reconcile pending operations. A screenshot or old tool result cannot prove that the restored application is on the same record. If a machine is lost, reacquire source material by authorised routes and rebuild working copies from durable objects. A surviving Task explains exactly which unsaved state could not be recovered.

7.5 Analysis and file transfer

The analysis supervisor launches a disposable job with selected immutable evidence mounts, a versioned program/environment, CPU/memory/time/output limits and an empty writable output area. Use Python with DuckDB/Polars and controlled libraries for large populations; spill to task-local storage. Document parsing and OCR also run outside the API/runtime process.

No general outbound network is available inside model-authored analysis. A legitimate need for more source material becomes a broker acquisition into new evidence, followed by a new admitted analysis input. The program has no cloud object-store, database, model-provider or browser-session credentials.

An analysis task has no credential-bearing ECS task role available to the program. Fargate sidecars share the task's identity/network boundary, so a privileged uploader sidecar is not an isolation solution. Use separately authorised staging and result collection through a narrowly scoped exchange endpoint; the task receives only handles for its admitted inputs and output reservation.

The supervisor measures actual termination, output bytes, hashes and resource use. It validates traversal, symlinks/hardlinks, special files, content and aggregate size before outputs can be registered. Separate complete stored results from bounded previews. A process-group kill alone is insufficient: terminate the complete job/container and confirm descendants and resources are gone, or report that cleanup remains unresolved.

Move files through scoped manifests: computer download → quarantine/inspection → evidence registration; selected evidence → read-only analysis input; validated analysis output → versioned working file/work product. A program's own manifest is a claim to validate, not trusted provenance.

Disable generic clipboard file transfer, SFTP and RDP drive redirection by default. Deliberate transfers use the scoped file picker and transfer operations. Uploading or replacing a document in a business application is a write under Permissions. Disable document macros by default; qualify any required macro execution in a separate disposable environment without unrelated live application credentials.

7.6 Operating cost

Use the supplied cost worksheet, editable assumptions, frozen rate metadata and standard-library Python calculator. **Reference: us-east-1, USD, 730-hour month, On-Demand shared tenancy, official rates retrieved 30 September 2026.** No discount, tax, support plan or per-tenant free egress allocation is assumed. Workload quantities are design assumptions, not measured customer usage. These are infrastructure costs, not customer prices.

Input	List rate used
Linux m6i.large	\$0.096/hour
Windows m6i.xlarge, including Windows OS	\$0.376/hour
gp3 / stored incremental snapshots	\$0.08 / \$0.05 per GB-month
Fargate Linux x86	\$0.04048/vCPU-hour + \$0.004445/GiB-hour
NAT	\$0.045/gateway-hour + \$0.045/processed GB
ALB / public IPv4	\$0.0225/hour + \$0.008/LCU-hour / \$0.005/address-hour
Internet outbound, selected first 10 TB tier	\$0.09/GB, without allocating the account-wide free allowance
S3 Standard / PUT / GET	\$0.023/GB-month / \$0.005 per 1,000 / \$0.0004 per 1,000
Managed AD Standard, minimum two controllers	\$0.06/controller-hour = \$87.60/month minimum
Office LTSC Standard / Professional Plus	\$15.70 / \$21.43 per named user-month
RDS SAL	\$10 per named user-month
Private interface endpoint	\$0.01/endpoint-AZ-hour + \$0.01/GB in the selected tier

The 12-user scenario assumes 60 useful active hours per user-month, two sessions/day over 20 days, ten-minute grace per session, and ten minutes/day of preparation: **70 paid running hours/user**. Add one clean spare for 200 staffed hours. Linux therefore uses **1,040 VM-hours = 720 useful + 120 grace/preparation + 200 spare**, versus 8,760 hours always on.

Each user has 20 viewing hours/month at an assumed 1 Mbps, with 10% extra reviewer viewing; the team delivers 118.8 decimal GB of display traffic. That bitrate is a cost input, not a demonstrated quality level. Each active user adds 2 GB other outbound traffic, 5 GB NAT source traffic, 20 GB retained S3 objects including versions, 2,000 writes/20,000 reads, and two hours of 2-vCPU/4-GiB analysis including startup allowance. Linux disks/snapshot blocks are 40/10 GB; Windows 100/20 GB. These are retained-size assumptions, not full disks multiplied by snapshot count.

The costed **regional desktop/network baseline is \$258.91/month**: two gateway/guacd replicas at 2 vCPU/4 GiB, two small egress proxies, two NAT gateways, one ALB and four public IPv4 addresses. Their

concurrency capacity must be measured. Add traffic charges; ALB capacity is budgeted conservatively from bytes plus non-byte headroom, not represented as its exact hourly max-dimension billing formula. Display traffic is not charged through NAT. Same-AZ routing is preferred; failover can add cross-AZ charges.

Scenario	Linux / Windows running hours	Scoped monthly subtotal	Per user
12 Linux users, active policy	1,040 / 0	\$431.55	\$35.96
12 Linux users, retained idle all month	0 / 0	\$308.83	\$25.74
12 Linux users, always on	8,760 / 0	\$1,169.47	\$97.46
10 Linux + 2 Windows, active	900 / 140	\$649.57	\$54.13
12 Windows users, active	0 / 840	\$1,133.27	\$94.44
12 Windows users, retained idle	0 / 0	\$797.63	\$66.47
12 Windows users, always on	0 / 8,760	\$4,111.19	\$342.60
Entire regional deployment serving one Linux user	70 / 0	\$271.79	\$271.79
Entire regional deployment serving one Windows user	0 / 70	\$439.20	\$439.20

The subtotal includes the specified computers, storage/requests, desktop/network baseline and traffic, analysis, plus Windows subscriptions/directory and endpoint allowances where applicable. **Each Windows row represents one organisation.** Each additional unrelated Windows firm adds its own minimum directory and **\$29.20/month endpoint capacity allowance** (four endpoint-AZ units, subject to actual provisioning), plus named-user charges. Twelve users across twelve firms therefore incur twelve organisation floors, not the single floor in the 12-user row. Windows licensing is not stopped by stopping a VM; RDS subscription termination also has continuing CAL-related billing conditions. The licence rates cover interactive entitlements only; unattended rights and application support must be qualified separately.

A solo SaaS customer does not get a whole regional infrastructure bill. Its direct Linux profile/use cost in this example is approximately **\$12.49/user-month**, plus a fair share of shared baseline, clean spare/headroom, application services and model use. The direct Windows/Office figure is **\$63.10/user-month**, plus its organisation's **\$116.80 directory/endpoint floor** and regional allocation. The one-user-deployment rows charge the whole regional baseline once and also include a conservative \$0.40 ALB headroom allowance; they show early low-occupancy economics or a dedicated deployment, not the price of every solo subscription. Allocate regional fixed cost once across actual reserved viewer capacity supported by the measured fleet, never hypothetical future customers; Windows organisation minima remain within that organisation's allocation.

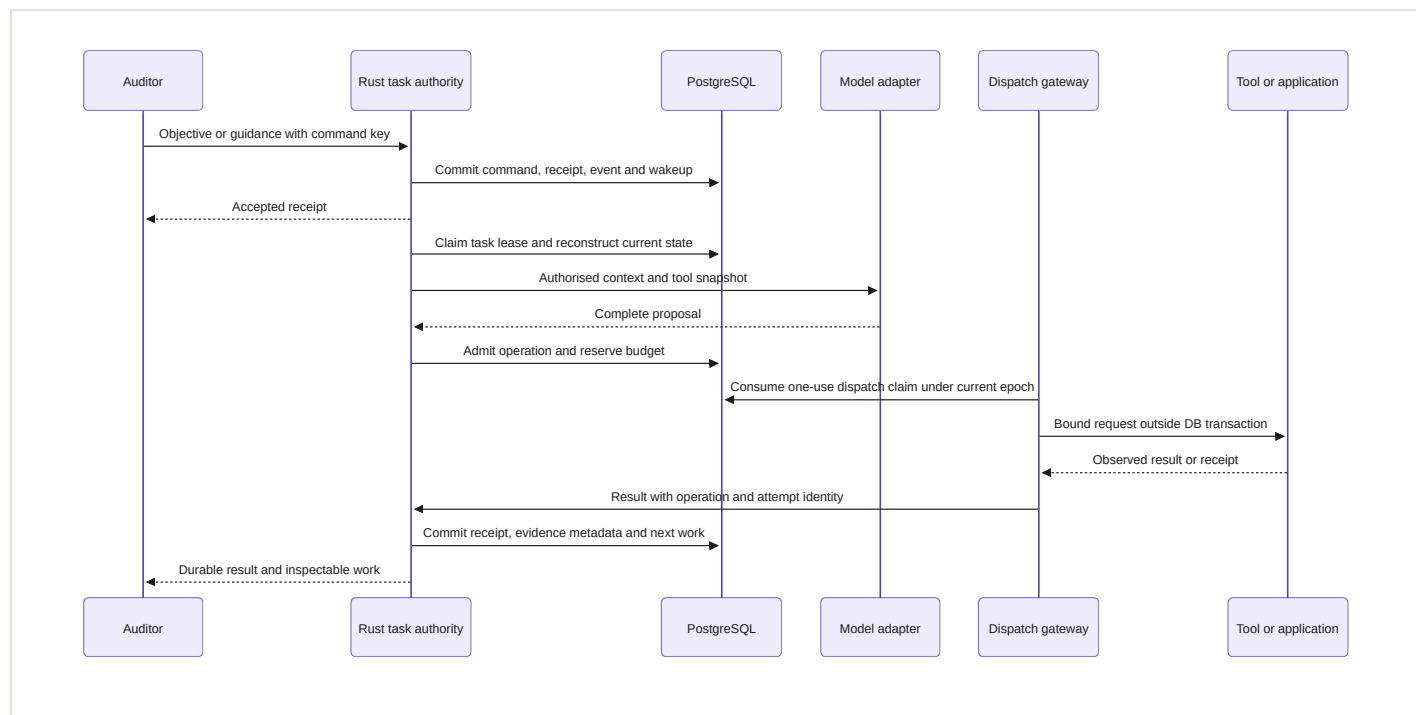
The workbook adds a separate **\$300/month unpriced application/data/operations allowance**, making the 12-Linux planning envelope **\$731.55/month before models**. This allowance is explicitly not a vendor quote or proof of sufficiency: separately size API/workers, PostgreSQL Multi-AZ/backups, identity, KMS/secrets, telemetry and image/build services before contracting. Model tokens/caches/images, paid connectors, extra retention/replay, cross-region/charged cross-AZ traffic, additional endpoints/IPs, tax, support, security operations and margin remain additional. Full service cost is **scoped subtotal + actual shared application allocation + actual model/provider usage + remaining operations/support**.

The readiness policy costs the Linux team \$11.52 for grace/preparation plus \$22.40 for the staffed spare and its disk: **\$33.92/month** above immediate stop/no spare. Always-on raises the scenario by **\$737.92/month**. At the stated volumes, raising average display traffic from 1 to 5 Mbps adds about **\$46.57/month** in egress/ALB bytes before extra encoding capacity. These sensitivities explain the policy; they do not establish its latency, hit rate or capacity.

Meter actual paid computer time, model usage, analysis and storage, with visible task/Check and firm budgets. Platform-owned clean-spare time is overhead, not a hidden per-user charge. Budget exhaustion withholds new costly work, preserves checkpoints and tells the person what remains; Stop, sign-out and access to earned results remain available. Offer separately priced dedicated/always-ready capacity when a firm needs it. Price seats with bounded included usage and explicit Windows entitlement, using observed regional utilisation to replace these assumptions.

8. Normal work, recovery and operational guarantees

8.1 Normal operation and result registration

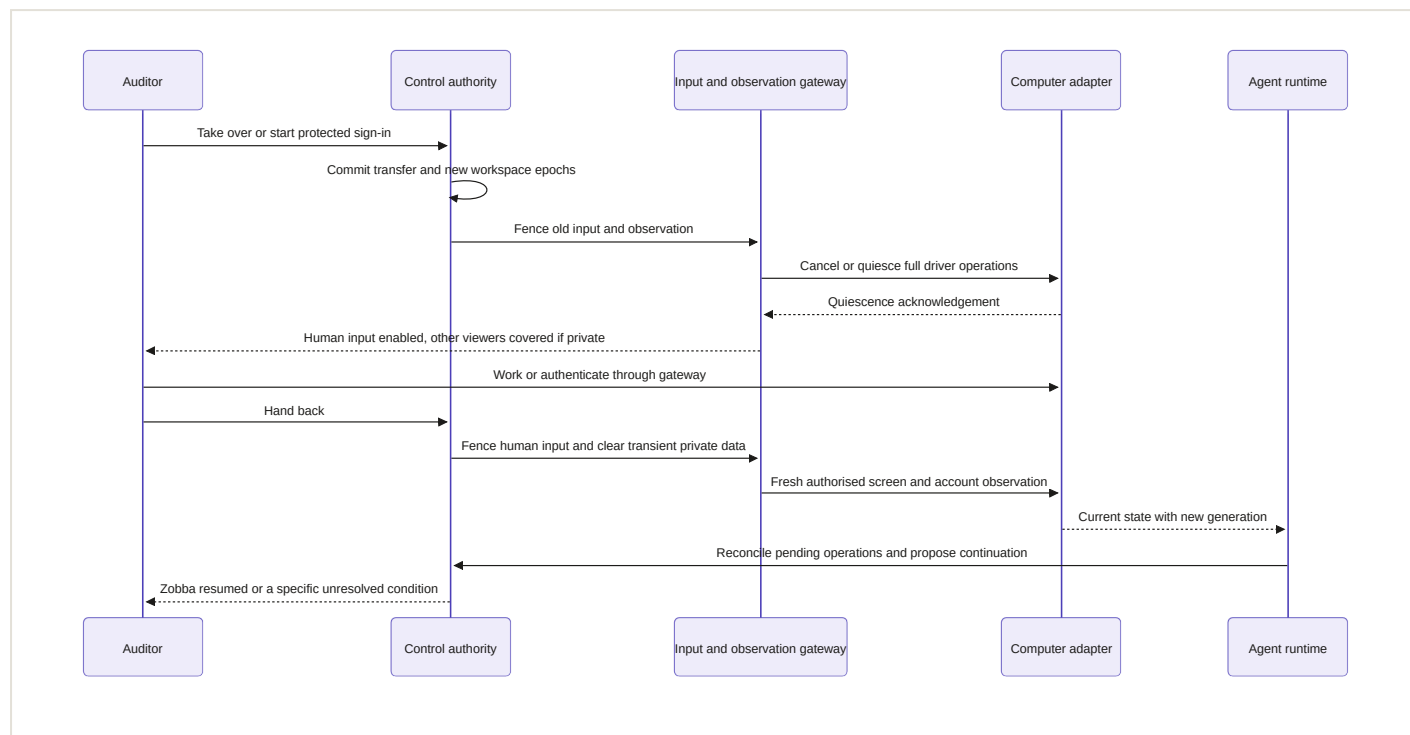


Design diagram 3

Large files use a reservation rather than an imaginary database/object-store transaction: reserve immutable object identity, conditionally upload, verify stored bytes and hash, then register evidence under that reservation. Retry registration against the same object after a lost acknowledgement. A different byte sequence is a different object. Quarantine orphan uploads for reconciliation and eventual cleanup; do not expose them as registered evidence.

Persist durable results before publishing UI wakeups. Stream token deltas as transient presentation, with bounded buffers and coalescing. Do not make a model's streamed "done" the committed result. On reconnect, obtain a current projection and replay durable events by cursor with the appropriate access checks.

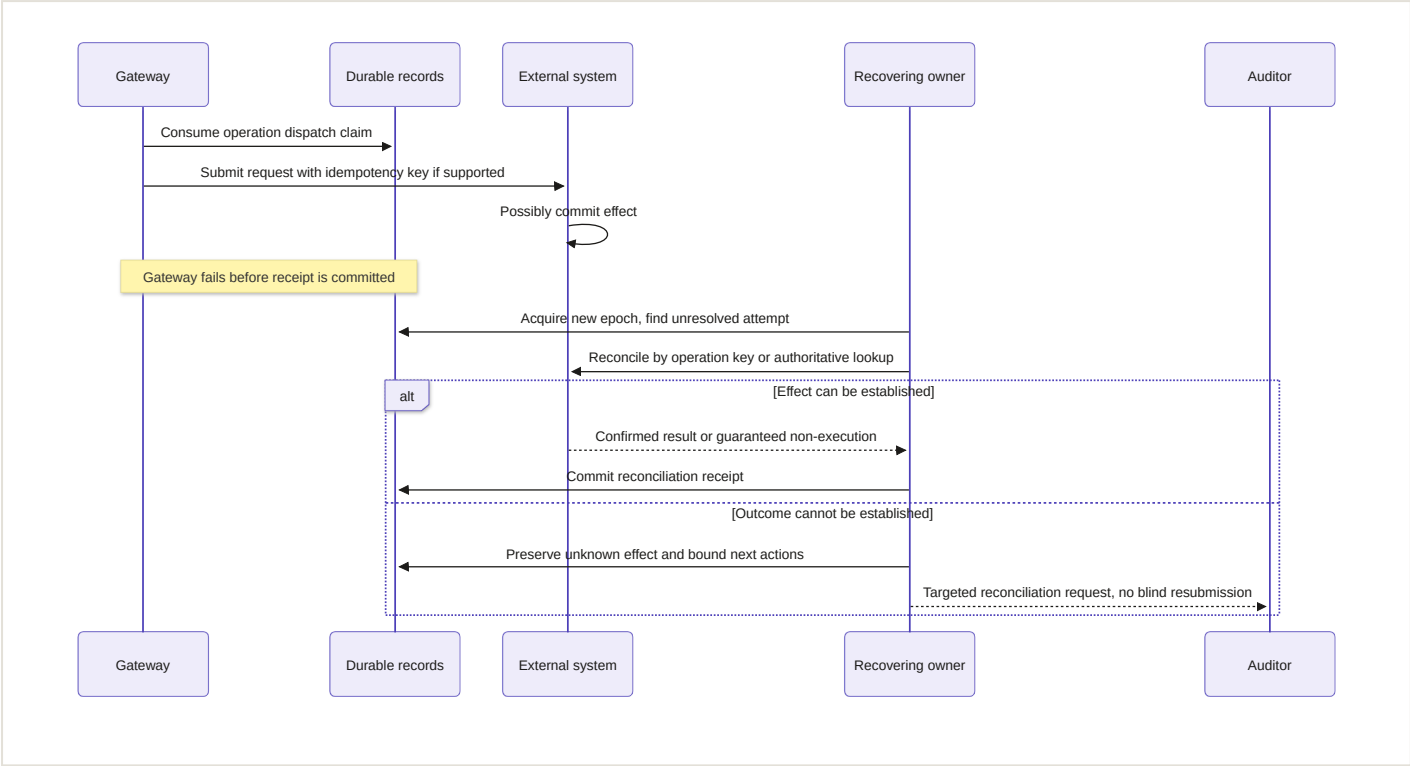
8.2 Takeover and protected sign-in



Design diagram 4

If quiescence cannot be established, the transfer remains pending or the workspace is recovered; it must not enable simultaneous human and agent input. The review view and independent analysis remain responsive.

8.3 Crash after a possible external effect



Design diagram 5

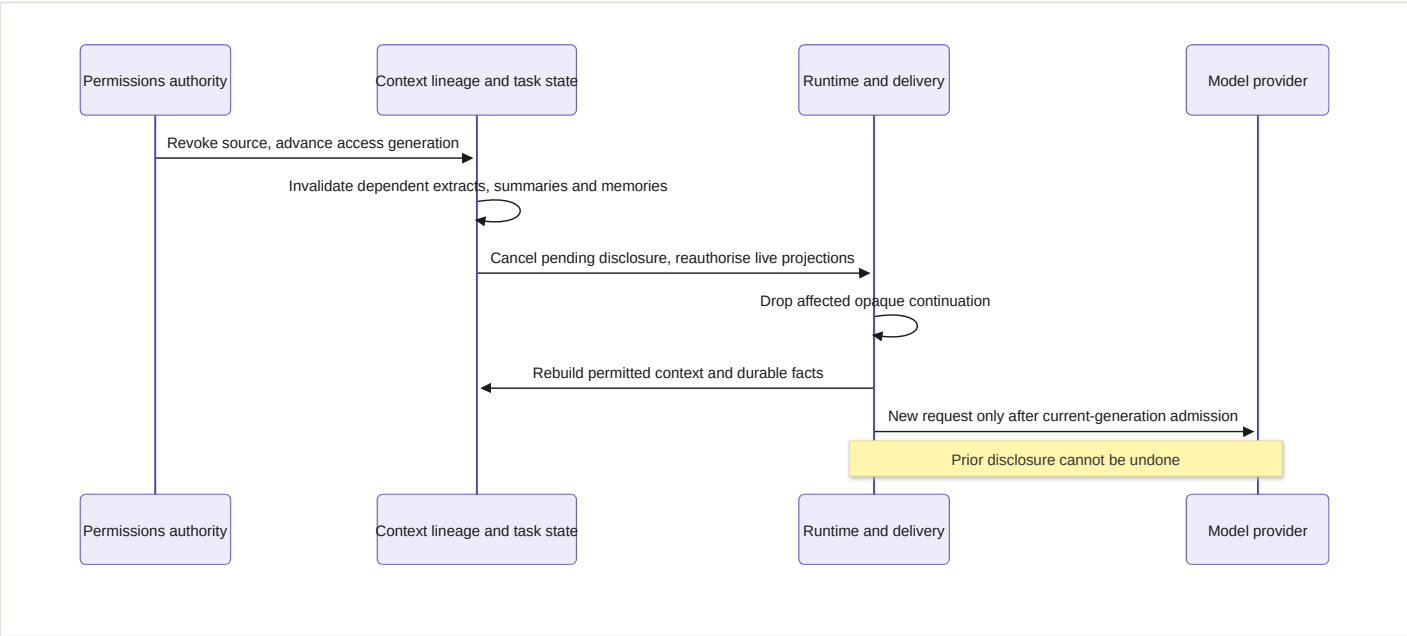
The user-facing message is “Outlook has not confirmed whether this message was sent. I’m checking Sent items.” A provider accepting a send is not proof of delivery. Never say “I sent it” when even acceptance is unknown.

Recovery boundary	Required response
Command commit fails	No accepted acknowledgement. Retried command key admits once or returns the existing receipt.
Operation admitted, dispatch claim not consumed	Known not dispatched through this path; revalidate before dispatch.
Dispatch claim consumed, result missing	Possibly dispatched. Reconcile; use a stable idempotency key only according to the provider’s actual contract.
Result received, receipt commit fails	Retry storing the same receipt. Do not perform the external action again to recreate a missing transcript item.
Receipt committed, UI acknowledgement lost	Return the original receipt and replay durable state.

Recovery boundary	Required response
Old worker returns after lease expiry	Reject new state changes/dispatch; retain an attributable late receipt for an already admitted operation under restricted authority.
Stop or revocation races with a result	Preserve the result/effect fact without restarting stopped work or disclosing newly forbidden content.
New evidence arrives after issue	Register it and open a successor/correction. Never mutate the issued package.
Machine disappears with child programs running	Supervise termination or revoke the isolated environment; report any unconfirmed cleanup. Task recovery does not assume the program stopped merely because its coordinator did.

Human reconciliation records the person, evidence and judgement. It remains distinguishable from provider-confirmed evidence. An absent search result establishes non-execution only when the tool contract guarantees that interpretation.

8.4 Context revocation and continuing work



Design diagram 6

A schedule, source event or answered question commits a scoped command and wakeup. It does not create a special execution path with weaker Permissions. Resume rechecks membership, account validity, method version and budget. A durable wait releases compute and remains visible to the assigned person.

8.5 Operation and service discipline

Use secure, HttpOnly server-session cookies, explicit CSRF protection for commands, short-lived attachment capabilities and current authorisation on reconnect. Do not expose credential-bearing handles in browser read models. Separate control requests, durable task events and high-bandwidth computer media so one slow stream does not block another.

Telemetry records scoped IDs, operation classes, timings, errors, resource use and bounded counters. Prompts, evidence contents, passwords and raw browser input are not ordinary logs. Retain per-invocation provenance and usage in protected application records, accessible through How it ran.

Use signed/versioned container artifacts, release-only database migrations and deployment of the tested revision. Back up PostgreSQL and evidence metadata/objects according to the same retention model; test restores. After point-in-time recovery, reconcile external effects that may have occurred beyond the restored database horizon before enabling automatic retries. An old backup must not cause an email, test approval or issued package to be sent twice.

If the restored system cannot reconstruct that interval from retained receipts and destination records, quarantine the affected tasks for explicit recovery review. An unknown recovery horizon is not permission to replay their effects.

8.6 Acceptance obligations

These define the intended design's correctness; they are not a request for another language benchmark or a separate research project.

Situation to exercise	What must be demonstrated
Duplicate command; failed admission transaction	One accepted operation and no external I/O before successful admission.
Two workers; expired owner returns	One valid epoch; stale commits and claim consumption refused.
Parent stopped, paused or revoked while a helper runs	Current delegation lineage blocks descendant dispatch; aggregate budgets remain bounded; late receipts do not restart the parent.
Crash at every operation boundary	Correct certainty, idempotent receipts and reconciliation without blind effect replay.
Guidance/Stop during a stalled provider stream	Durable prompt control acceptance and visible accepted/applied distinction.
Takeover during Playwright retries or held keys	Old driver fully fenced before new input; no later old-epoch action.
Private sign-in with several viewers	No credentials or private frames reach models, observers, voice capture, logs or replay.

Situation to exercise	What must be demonstrated
Same source via API, MCP and computer	Consistent account/purpose/action restrictions, including a destructive tool falsely labelled read-only.
Permission change during context assembly or late result	No fresh forbidden disclosure; dependent summaries/continuations/projections invalidated.
Cross-client data, guessed IDs and pooled connections	No scope leakage through database, search, object grants, models or workspaces.
Hostile documents and model-authored programs	Bounded isolated execution; no task-role credential access; validated output collection.
Slow subscribers and large outputs	Bounded memory; complete durable results remain recoverable; previews show truncation/coverage.
Concurrent artifact edits and late evidence	No lost update or overwritten approval; exact-version review and successor records.
Duplicate/missed schedule or evidence notification	One occurrence/continuation, explicit catch-up policy and revalidated authority.
Session expiry, device-bound login and VM loss	Honest reconnect/sign-in/unsupported states; no claim of preserved unsaved state.
Source population incomplete or absent	No invented zero count, false complete population or unsupported "no exception".
Deterministic versus judgment assessment	Exact decimal/date boundaries; rubric and contrary evidence retained; calculation failure distinct from control failure; no approval from model confidence.
Multiple criteria, ambiguous matches, samples and verified zero activity	Reconciled grain-specific counts, distinct exception subjects, limited inference and an honest no-activity result.
Admin edits methodology or a skill during work	One attributable Save, correct scope/effective binding, no invented second approver, safe-boundary rework and preserved issued versions.
First complete task and long-task recovery	Applicable method and skill used, scoped knowledge retrieved, material conflict exposed, exact decisions preserved through compaction, and cited output reviewed under the correct team/solo rule.

Situation to exercise	What must be demonstrated
Schedule edit, new method and late evidence for one period	Same logical occurrence; new binding/evaluation revision where appropriate, with no duplicate send or finding.
Personal connection owner leaves; firm consent is withdrawn	Dependent delegation blocks, accountable person notified, explicit rebind without impersonation or silent source substitution.
Provider accepts asynchronously or returns partial/unverifiable output	Pending remains pending; completeness and effect certainty are not inferred from HTTP success.
Computer readiness, takeover and regional load	Measured latency/availability and per-session cost against §7 targets, including reconnect, full warm pool, stopped computer, private sign-in and slow subscribers.

Audit-quality evaluation is separate from runtime correctness: use synthetic engagements with known populations, conflicting policies, omitted records, ambiguous joins, planted exceptions and unsupported allegations. Judge coverage, calculation accuracy, supported claims, correct uncertainty, useful investigation and reviewable output under a fixed method. Model/rubric versions run against these cases before qualification. They are acceptance obligations of this design, not claims of completed product tests or an additional language-selection study.

9. What to keep, adapt, rebuild and remove

The inspected checkout and remote main both point to

9c17d19e84d3df3e5da48a48ac494b8071696e9b, including merged Story 10.12. Current code evidence matters more than a stale story status. No application changes, schema reset or fresh test run were performed for this design.

The present schema requires every audit Run to reference a Procedure and Procedure Version and fixes P-1–P-4 templates. Its model gateway produces bounded JSON under a prescribed work-item loop. Its control leases govern Run commands, while the workspace-capability contract explicitly supplies a read-only viewer. These are useful earlier solutions, but they are not the continuing task and real computer model specified here. A fresh design is cleaner than nullable procedure references and parallel engine modes.

Area	Recommendation	Destination and consequence
Pair identity, tokens and reusable React presentation	Keep / adapt	Keep assets, accessible components, evidence inspection and firm-document treatment. Rebuild navigation and data bindings around engagements/tasks.
Next.js application shell, server actions and procedure/run routes	Rebuild	React/Vite frontend over Rust APIs. Port useful views; do not preserve an extra Node domain layer.
Builder, guided preparation and section-by-section authoring	Remove as the main flow	Conversation and Working brief replace them. A recurring Check has a focused definition/review surface, not the old wizard.
compiler-1, frozen executable plans, fixed P-1–P-4 grammar	Remove	One Rust task engine; reusable audit methods live in methodology/Check packages. No compiler-2 compatibility engine.
Node worker and work-item orchestration	Rebuild	Rust task authority, cancellable activities, resource claims, helpers and operation receipts. Keep Node only where a mature tool driver needs it.

Area	Recommendation	Destination and consequence
Vercel AI SDK model gateway	Rebuild	Native provider adapters and a portable Zobba representation. Preserve usage reservation, model identity and safe error lessons.
PostgreSQL technology	Keep	New tenant/client/engagement/task schema with current scoped principals and enforced constraints.
Existing schema, Drizzle migration chain and old Run IDs	Replace for new development	Fresh SQL migration baseline. Archive history for reference; no synthetic-history migration programme.
pg-boss and Node consumers	Replace	PostgreSQL work/inbox/outbox records managed by Rust. Preserve atomic work-and-queue commit.
S3 evidence lifecycle	Adapt strongly	Preserve reservation, conditional upload, read-back verification, guarded registration and scoped downloads; generalise ownership and lineage.
Hashing, canonicalisation, audit event integrity	Adapt	Carry useful golden vectors and tamper-evident audit events into scoped/versioned records. Do not confuse a hash chain with complete evidence or task state.
Deterministic arithmetic and evidence-quality rules	Adapt selectively	Exact calculations, qualified absence, ambiguous matching and incomplete populations become reusable methods. Remove client-specific criteria from runtime law.
Better Auth integration	Replace; retain behaviour tests	Managed OIDC plus Rust sessions/current authorisation. No old global role values need survive the fresh schema.

Area	Recommendation	Destination and consequence
Static credential manifests and synthetic sign-in assumptions	Rebuild custody	Broker-owned OAuth, scoped account bindings and private human sign-in. Retain secret-containment tests.
Solari/local browser boundary and worker-embedded headless browser	Replace target boundary	Managed computers and a driver abstraction. Browser-context isolation remains a useful test, not proof of VM/tenant isolation.
Run control leases and manager transfer	Adapt semantics, rebuild gateway	Keep epochs, exact receipts and accepted controls across reassignment. Add actual input/observation fencing and independent ownership concepts.
Conversation, questions and fixed command phrases	Adapt ledger; rebuild interpretation	Durable accepted/applied guidance, attributable decisions and pagination survive. Exact English phrases cease to be the task interface.
Live timeline, replay and record detail	Adapt	Cursor truth, explicit gaps, exact evidence links, missing-versus-empty distinctions and stable history. Add complete pagination and bounded clients.
Registrations and existing write bans	Rebuild	Purpose/account/resource/action Permissions across APIs, MCP and computers; allow designated test writes and authorised audit coordination.
Notifications and schedule fields	Rebuild continuing-work model	Reuse transaction/retry lessons. A schedule field alone is not a proven recurring assurance service.
Northstar, LoanCore, ProdConsole and synthetic datasets	Keep as optional fixtures	Valuable test worlds and example methods; remove them from production topology and universal behaviour.

Area	Recommendation	Destination and consequence
Tests, mutation style, CI and release discipline	Adapt	Preserve desired behaviours, browser/accessibility checks and exact-revision release. Retire compiler-shape, fixed-vocabulary and legacy-compatibility assertions.
Railway web/worker/demo deployment topology	Replace for chosen target	AWS control plane, isolated computers and analysis jobs. Keep migration-at-release and tested-image discipline.

Carry forward selected methodology documents, templates, fixture datasets, source references, golden calculations and useful draft work. Do not bulk import synthetic histories, provider session handles, secrets or every old identifier. Reconnect accounts into the new custody model. A clean restart means losing old active sessions and development workflow continuity; that is an acceptable recommended cost here, not a hidden migration promise.

Story 10.12's precise replay gaps, evidence-to-record links, bounded-history truth and retained unhonoured requests are particularly worth preserving. Replace arbitrary first-100/500 history limits with cursor access rather than preserving truncation as a feature. The repository anchors and behavioural test map are in the supporting disposition evidence.

9.1 Selective Codex reuse

Use Codex as an engineering reference, not the embedded runtime or a product dependency. Both studies examined **8ffd91e42aa001b7e897bea812b02f89264f9fa0**; selected source seams were directly rechecked at that revision for this design.

Candidate	Treatment
unified_exec/head_tail_buffer and its tests	Adapt for bounded diagnostic previews; separately retain complete output where required and account for truncation/marker bytes.
utils/string UTF-8 truncation and tests	Adapt presentation helpers; do not use token heuristics to establish evidence completeness or real provider limits.
http-client RetryAfter and tests	Adapt captured monotonic retry deadlines, bounded by task/provider budgets. Never infer that uncertain effects may be repeated.

Candidate	Treatment
codex-mcp prepared binding and tests	Reuse the pattern of exact account/client/catalog binding and stale-call refusal, with Zobba's own durable authority.
keyed request serialisation, task cancellation and PTY lifecycle	Carry design patterns and adversarial tests; avoid importing a second scheduler or assuming process-group termination is complete isolation.
codex-core, transcript recovery, global memory and default execution-policy semantics	Do not import wholesale. Their local trust/durability assumptions and hosted dependencies do not supply Zobba's audit guarantees.

Direct source inspection found that recording a tool call before dispatch does not make failed persistence a hard dispatch barrier in the studied Codex path. Missing tool outputs can become synthetic "aborted" transcript entries; that does not establish external non-execution. Hidden tool visibility is not authorisation, and MCP read-only hints are not trustworthy effect classification. Report B's policy probe also demonstrates why mandatory denial cannot be assumed from merged shell allow rules. These lessons inform the stricter Zobba operation and Permissions contracts.

The reference repository is Apache-2.0 with applicable NOTICE material; selected units and dependencies still need file-level review. For each adopted or translated unit, keep the exact upstream revision/path, local destination, modifications, license/notices and relevant tests. This design downloaded bounded reference source; it did not vendor or license-clear a future production dependency tree.

10. Replace the planning model coherently

This package is the proposed replacement design baseline. Keep earlier documents as dated history, then publish a consolidated active set after owner review. Do not keep contradictory active addenda. Existing identifiers remain historically stable: mark retired requirements/ADs as superseded and map them to new requirements rather than reusing their numbers for different meanings.

Active document family	Required revision
PRD and addendum	Replace procedure-first value, fixed templates and deferrals with the complete engagement/task experience, audience, supported profiles, review and continuing assurance.
Experience and design rules	Consolidate Pair, explicit Follow Zobba, real computer states, private sign-in, responsive guidance, standing Permissions, three roles, Admin Save and honest team/solo review. Remove the fourth methodology-owner role, ordinary-edit approval ceremonies, blanket ask-before-every-effect rule and incorrect unknown-send wording.
SPEC, glossary and validation-preservation register	Define Task, work cycle, operation/attempt/receipt, computer generation, evidence, claim, work product version and Check. Preserve behaviours by meaning rather than old type names.
Architecture spine	Replace dual-engine/TypeScript bridge choices with one Rust authority, fresh schema, scoped identity, managed execution, native providers and durable continuation. Retain useful invariants with revised ownership.
Code-disposition/course-correction papers	Supersede compiler-1 compatibility, delayed Builder retirement, compiler-2 coexistence and retained old worker/queues. The current brief expressly removes those constraints.
Contracts	Replace the families below as a consistent set, with shared identities, authority, state and error vocabulary.

Active document family	Required revision
Epics, stories and release plan	Derive them after design review. Old numbering, slice boundaries and deferrals do not determine the new scope or delivery order.

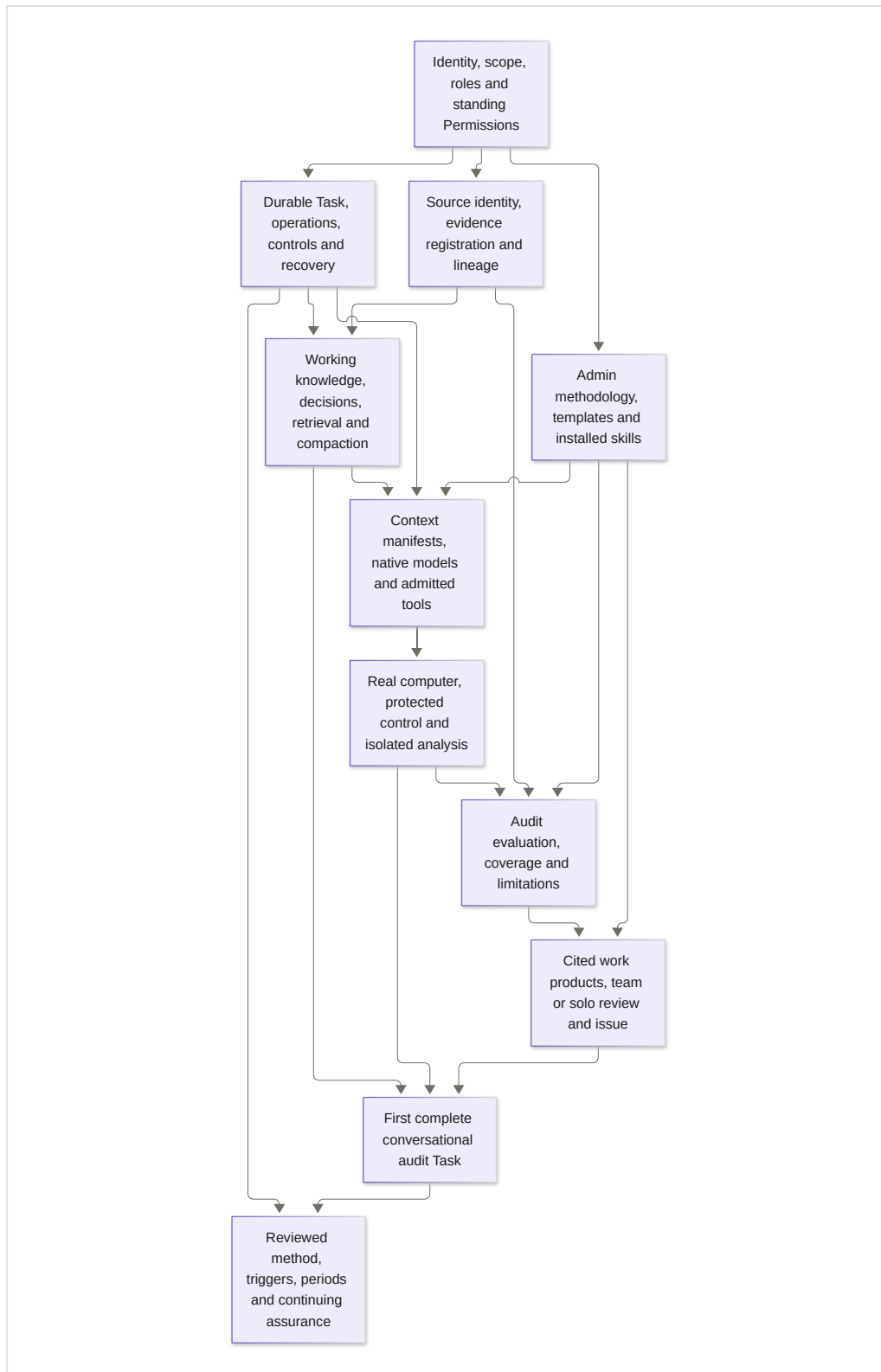
The replacement contract set should cover:

1. Task commands, accepted/applied guidance, waits, ownership and cancellation.
2. Operations, attempts, one-use dispatch claims, outcomes and reconciliation.
3. Identity, scoped Permissions, connections, delegation and disclosure.
4. Native model content/events, tool descriptors, budgets and provider continuity.
5. Computer lifecycle, input/observation control, protected sign-in and file transfer.
6. Isolated program execution and verified output registration.
7. Source acquisition, population/coverage, typed criteria, evaluation revisions, evidence, derivations and claim support.
8. Work product editing, review, issuance, corrections and retention.
9. Admin configuration, task/skill bindings, scoped working knowledge, context lineage, compaction and methodology standing.
10. Recurring method contracts, logical-period occurrences, evidence requests, subscriptions, notifications and missed-event recovery.
11. Scoped event delivery, replay, bounded consumers and reconnect.

The old executable-plan/agent-execution/Gate contracts are replaced. Evidence and replay contracts contribute semantics but gain new ownership and general document/data support. Run request/pause/escalation contracts contribute durable receipts and waits, with computer input control added as a separate contract. Concrete source paths and the old-to-new contract mapping are preserved in disposition evidence.

11. Capability dependencies

The first complete experience is an auditor giving an objective, Zobba applying the relevant methodology/skills/knowledge, acquiring real authorised material, using its computer and analysis, accepting guidance and surviving interruption, and producing supported work for the appropriate review/issue path. Methodology is required to know what to test and how to report it; working knowledge is required to continue sensibly. Neither can be added after that experience is declared complete.



Design diagram 7

The arrows describe required capabilities, not delivery stages. At runtime, new acquired evidence updates working knowledge and informs the next cycle. Source registration therefore exists before acquisitions begin; it does not depend on completing a particular evidence collection first.

Capability needed in the complete task	Dependencies and visible proof
Methodology and skills	Admin Save/version/assignment, source interpretation, trusted skill manifests and task bindings. The brief names the applicable period/rules/template, and a relevant technique is actually used.
Working knowledge	Scoped evidence lineage, exact decisions, authorised retrieval, freshness/conflict rules and compaction. The task uses relevant prior facts, accepts a correction and recovers it after interruption without crossing clients.
Real work and responsive control	Standing Permissions, admitted tools, operation receipts, broker, managed computer and isolated analysis. The auditor can watch, privately sign in, take over and stop while useful work persists.
Audit evaluation	Criterion/basis versions, typed observations, population/sample manifests, exact methods/rubrics and limitation rules. Claims expose their test and evidence; missing input cannot become a pass or fabricated failure.
Work products and human responsibility	Stable content/claim versions, firm templates, evidence dependencies, eligible roles and team/solo mode. The same journey reaches review/issue with truthful attribution and successor corrections.
Continuing assurance	All of the above, plus reviewed Check contracts, current service delegation, logical-period identity, triggers, deadlines, budgets and issue continuity. Next-period evidence uses the same meaning; material drift and incomplete coverage are explicit.

The AP example in §4.5 is a complete-task acceptance journey: method and skill selection; relevant prior system knowledge; population acquisition and computer inspection; guidance and recovery; exact evaluations with unresolved inputs; paper and applicable review; recurring promotion; one later occurrence with late evidence and preserved prior results. A smaller file-only prototype may help engineering, but does not redefine this complete product boundary.

Helper tasks depend on scoped context, resource ownership and safe output merges. Native Windows depends on the computer contract plus qualified applications, authentication and licensing. Larger catalogs and more sophisticated retrieval can expand; applicable methodology, skills, working knowledge and honest review already belong in the first complete task. The build plan should be derived from these dependencies after design review.

12. Remaining business decisions

The clean Rust backend/fresh schema, continuing Task, real managed computer, standing Permissions, team and solo support, and Admin-owned configuration are settled direction. The design does not ask for those choices again. Three commercial commitments remain; engineering can use the stated assumptions until they are made concrete.

Business decision	Recommendation	What remains to specify
Supported customer applications and service promise	Sell the complete Linux/browser working experience as standard, including qualified firm connections; native Windows is a separately qualified paid profile in the same product. Publish app/account/authentication support and distinguish interactive from unattended support.	Name the initial customers' required applications and authentication methods, whether native Office/unattended Windows is a contractual launch requirement, and supported service hours/concurrency. This determines image qualification, tenant directory/licensing and warm capacity, not a second architecture.
Data location and retention contract	Hosted multi-tenant SaaS with one primary region per organisation, explicit allowed model/connector destinations and firm-configured retention. Keep issued evidence/manifests under the agreed audit retention; give transient computers and optional replay much shorter lifetimes.	Select launch geography and allowed processing destinations against actual customer obligations, plus retention/deletion/legal-hold terms. US East prices in \$7 are a reproducible reference, not a residency commitment; rerate the chosen region before contracting.

Business decision	Recommendation	What remains to specify
Price and included usage	Seats with included model/analysis/computer usage, visible budgets and bounded overage; charge Windows entitlement separately. Standard hosted model billing is the default; optional firm-paid provider credentials use the same policy/custody. Platform spare capacity is Zobba's overhead, not a surprise customer usage charge.	Set price, allowance, overage ceiling and margin using the worksheet, expected deployment occupancy, model mix, support and actual pilot usage. Do not sell unlimited persistent desktops or treat marginal compute as total cost.

Firm-specific criteria, sampling and review requirements are ordinary Admin configuration and engagement decisions within this product, not unresolved platform choices. No production system, purchase or application rewrite is authorised by this design document itself.

13. Evidence, scope and review status

The current direction brief and the latest user request control the design. Revision 2 retains the lead architecture and uses the alternate agent’s design as a completeness check. Report A supplies the main task ownership/recovery/context analysis; Report B and its appendix add policy-probe evidence, execution cases and reusable code/test candidates. Their proposed prototype comparisons, legacy-preservation assumptions and earlier deferrals were deliberately not adopted.

Source	Use and evidential limit
Zobba_Product_and_Architecture_Direction.md, §§1–10	Product target and scope. Treated as reference material adopted by the user’s request, not as independent permission to implement, deploy or delete anything.
Alternate agent design, especially §§1.3, 2.5, 2.7, 2.10–2.11 and 5	Completeness source. Adopted useful source/evidence-request, connection ownership, skill/context and recurring-method detail; rejected its speculative suspend/cost claims, blanket confirmations, universal self-review ban, configuration approval ceremonies and late knowledge stage.
Zobba-Codex-Source-Study-2026-09-29.md, especially §§4–8	Primary engineering study. Observed source facts separated from its proposed Zobba architecture and unexecuted experiments.
codex-source-study.md and appendix A01–A10/B1	Supporting dispatch, context, provider, isolation and failure evidence. No inference that all inspected suites or hosted services were tested.
Codex at 8ffd91e42aa001b7e897bea812b02f89264f9fa0	Selected source seams and small reuse candidates directly verified; LICENSE/NOTICE retained with the reference snapshot.
intellifin-audit at 9c17d19e84d3df3e5da48a48ac494b8071696e9b	Clean checkout and remote HEAD verified. Current schema, compiler, gateway, evidence, UI, review, tests and deployment inspected for disposition.
Supplied Pair design pack	Identity, tokens, eight reference screens and experience rules reviewed. Screens are design references, not proof that their controls are implemented.

Source	Use and evidential limit
Official infrastructure documentation and frozen pricing evidence	Confirms mechanisms, material limits and specific list-rate inputs. Scenario quantities, readiness targets and shared allocations are design assumptions; no Zobba performance, compatibility or total service bill is established.

No separate dots screenshot was present among the supplied extracted files. Its experience was used from the brief’s description; the design does not claim to have visually inspected that missing image. This does not block the product or architecture recommendation.

Key engineering evidence:

- Codex complete-call handling and persistence: stream_events_utils.rs, session/mod.rs.
- Exact prepared connection binding: codex-mcp binding.rs.
- Existing procedure-bound schema: schema.ts.
- Existing evidence lifecycle: evidence-package.ts.
- Existing read-only viewer boundary: workspace-capability-v1.md.

Key platform references checked for this design:

- Apache Guacamole: architecture, embedding, protocol/session joining, transfer and recording controls.
- AWS: EC2 stop/start, Fargate security, task IAM roles, Cognito federation.
- Windows/Office: AWS user subscriptions, setup prerequisites, Office LTSC 2024, unattended licensing, unattended technical constraints.
- Costing and responsiveness: reproducible worksheet and scope, selected official rate evidence, Office/licensing and additional rate evidence, managed-computer design detail. The official rate URLs and effective/retrieval dates are preserved with each input.

Supporting inspection notes provide the detailed traceability behind the recommendation: product experience, source mechanisms and reuse, current-code disposition and workspace infrastructure. Where a research note describes an alternative or an earlier assumption, the integrated recommendation in this document is the proposed design.

Revision 2’s supporting analysis is the completeness comparison, audit evaluation and recurring methods, and methodology, skills and working knowledge. These explain the consolidation; this integrated document governs where notes discuss alternatives. The supplied source documents remain unchanged. The three remaining business commitments are only those in §12.

The package was checked for consistency across product controls, task ownership, operation uncertainty, Permissions, input fencing, credential privacy and review. The cost calculator was independently checked and reproduced; diagrams, links and rendered editions were verified. It does not represent a newly implemented or tested application runtime. No application implementation, live service, database or existing authoritative planning document was changed by this design work.